

Security Lab Solution Document

Network Security, Privacy and Remote Access



Created By: Paul Leone
April 1, 2026

Contents

Network Security Architecture.....	3
Network Firewall/Router Architecture.....	5
High-Availability pfSense Cluster.....	5
OPNsense Microsegmentation Firewall	8
Fortinet Fortigate 30D Appliance.....	9
Palo Alto PAN-OS KVM Virtual Firewalls.....	14
Firewall Policy Architecture	18
Intrusion Detection/Prevention Solutions.....	27
Suricata Intrusion Detection/Prevention System on pfSense	27
Snort Intrusion Detection/Prevention System on pfSense	27
Custom Ruleset Architecture.....	28
CrowdSec Behavioral Threat Intelligence.....	32
Multi-Engine Intrusion Detection & Prevention	34
Layered IDS/IPS Strategy:.....	34
SafePoint/Safeline Web Application Firewall (WAF).....	35
Component Architecture:.....	36
Configuration Overview.....	37
Active Protection Modules	38
Security Control Summary	41
Network Security Controls:.....	41
Detection & Response Capabilities:.....	41
Operational Resilience	41
Redundancy Architecture:.....	41
Failure Scenarios & Response:.....	41
Monitoring & Alerting:.....	41
Backup & Recovery:.....	42
Use Cases & Deployment Scenarios.....	42
Scenario 1: Privacy-Enhanced Web Browsing	42
Scenario 2: Remote Lab Access While Traveling.....	42
Scenario 3: Threat Intelligence Sharing & Automated Response	42
Scenario 4: Multi-Region Content Testing.....	42
Threat Modeling.....	42
Threats Addressed:	43
Attack Surface Reduction:	43
Privacy and Remote Access Architecture.....	43
Private Internet Access (PIA) – Encrypted Egress VPN.....	44

Tailscale – Zero-Trust Remote Access	45
Node Inventory	46
Cloudflare - Secure Service Exposure & DNS Management.....	47
Tor Browser – Anonymous Outbound Browsing.....	49
Summary	50
Appendices.....	50
Screenshots.....	50
Firewall Rule Table.....	52
Custom IPS/IDS Ruleset – Additional Detail	56

Network Security Architecture

A defense-in-depth edge security architecture implements multiple layers of inspection, filtering, and threat mitigation across network perimeter, application layer, and endpoint boundaries. The security stack spans four independent firewall platforms (pfSense HA, OPNsense, FortiGate 30D, Palo Alto VM-Series), multi-engine intrusion detection and prevention (Suricata, Snort, CrowdSec), next-generation application and identity-layer controls (Palo Alto App-ID/User-ID, WildFire), application-layer filtering (Safeline WAF), network security monitoring (Zeek, ntopng), and encrypted tunneling (VPN/Zero-Trust access) to provide enterprise-grade network protection.

Security Impact: Four independent policy engines provide overlapping enforcement that no single platform can deliver alone. Palo Alto NGFW adds App-ID and User-ID layers that signature-based firewalls cannot replicate. Multi-engine IDS/IPS (Suricata + Snort + CrowdSec) reduces single-engine miss rates from ~15-20% to <5%. Passive NSM (Zeek + ntopng) captures full protocol metadata and NetFlow across all monitored segments without disrupting traffic flows. High-availability clustering ensures uninterrupted perimeter protection during maintenance. Centralized logging and NetFlow aggregation from all firewall and routing platforms enables threat correlation across the entire security stack.

Deployment Rationale: Enterprise networks deploy layered security controls because attackers increasingly use evasion techniques (encryption, polymorphic malware, living-off-the-land tactics) that bypass signature-based detection. This architecture mirrors enterprise SOC designs where multiple detection engines provide overlapping coverage. The inclusion of Palo Alto NGFW alongside traditional stateful firewalls reflects production environments where App-ID and User-ID enforcement replaces port-based rules and IP-to-user mapping tables. The physical Cisco 3560X and virtual Cisco IOS/IOS XE routers demonstrate proficiency with enterprise routing infrastructure, OSPF dynamic routing, and L2 security hardening. The NSM sensor fills the gap general infrastructure monitoring tools leave — providing protocol-level and flow-level network visibility that EDR and SIEM alone cannot cover.

Architecture Principles Alignment:

- **Defense in Depth:** Seven security layers — firewall ACLs (four platforms) → App-ID/User-ID NGFW enforcement → IDS/IPS inline blocking (Suricata + Snort) → behavioral detection (CrowdSec) → WAF (Safeline) → NSM passive monitoring (Zeek + ntopng) → endpoint protection (Wazuh EDR) ensure a single-layer bypass cannot compromise the full network.
- **Secure by Design:** Default-deny firewall policies across all platforms; encrypted VPN tunnels for remote access; automated signature updates for IDS/IPS; OSPF MD5 authentication prevents route injection; Palo Alto WildFire sandbox analysis applied to all permitted flows; NSM sensor operates as observe-only with no routing function, eliminating it as an attack surface.
- **Zero Trust:** Palo Alto User-ID maps Active Directory group membership to firewall policy enforcement follows identity, not IP address; Tailscale device authentication required for remote access; no implicit trust between network zones; microsegmentation isolates workloads across dedicated VLANs with explicit inter-zone ACLs; all east-west and north-south traffic flows visible via Zeek metadata and ntopng NetFlow.

Security Platform Overview:

Layer	Platform	Function	Coverage
Perimeter Firewall	pfSense HA Cluster	Active/passive HA; stateful inspection; VPN termination; IDS/IPS; CrowdSec bouncer	All inbound/outbound traffic

NGFW	Palo Alto VM-Series (x2)	App-ID, User-ID (AD), WildFire, IPSec site-to-site, GlobalProtect VPN, OSPF, NetFlow	DMZ, ISO_LAN1, Prod_LAN, Site2
Microsegmentation FW	OPNsense	Zone-based ACLs; CrowdSec enforcement; inter-VLAN isolation	ISO_LAN boundary
Management FW	FortiGate 30D (Physical)	L3/L4 policy; SSL VPN; FortiOS management platform	VLAN 3 / 192.168.3.0/24
Routing Infrastructure	Cisco vIOS R1/R2, CSR1000V R3, 3560X	OSPF Area 0; NetFlow export; L2/L3 switching; DHCP snooping; port-security	All lab segments
Intrusion Detection/Prevention	Suricata + Snort	Signature + anomaly detection; inline blocking; 40,000+ rules	All LAN, VPN interfaces
Behavioral Detection	CrowdSec	Community-driven behavioral analytics; firewall bouncer enforcement	Logs from all platforms
Application Firewall	SafeLine WAF	OWASP Top 10; bot mitigation; HTTP-flood DDoS; ML anomaly detection	All protected web portals
Network Security Monitoring	Zeek + ntopng	Protocol metadata (DNS, HTTP, TLS, SSH, SMB, RDP); NetFlow aggregation from all sources	prod_lan, lab_lan1, lab_lan2
Threat Intelligence	pfBlockerNG + MISP	IP reputation; GeolP blocking; IOC correlation	Firewall and SIEM

Network Segmentation & Zone Architecture:

Zone / VLAN	Subnet	Gateway	Purpose
Prod_LAN (VLAN 10)	192.168.1.0/24	pfSense 192.168.1.254	Production environment; lab services
Lab_LAN1 (VLAN 100)	192.168.100.0/24	pfSense / R1 192.168.100.6	Lab Services, VMware, PKI
Lab_LAN2 (VLAN 200)	192.168.200.0/24	pfSense / R1 192.168.200.6	K3s Cluster, SOC namespace, server-admin workloads

Ext_LAN / DMZ (VLAN 20)	192.168.2.0/24	PA-FW 192.168.2.138 / R3 192.168.2.9	DMZ services; external-facing workloads
ISO_LAN1 (VLAN 120)	10.20.0.0/24	PA-FW 10.20.0.138	NGFW-enforced isolated segment
ISO_LAN2 / MGMT (VLAN 30)	192.168.3.0/24	FortiGate 192.168.3.1 / R2 192.168.3.9	Management VLAN; isolated testing
HA Sync (VLAN 110)	10.10.0.0/24	pfSense dedicated	pfSense CARP state synchronization
Cisco P2P + PA OSPF	10.30.0.0/29	R1 10.30.0.1 / PA-FW 10.30.0.4	OSPF peering between Cisco routers and PA-FW
Site2 Branch (simulated)	10.40.0.0/24	PA-FW Site2 10.40.0.2	Simulated remote branch via IPSec tunnel

Detection & Response Capabilities:

Alert latency	Suricata/Snort alerts forwarded to Splunk/Elastic within seconds
Automated blocking	CrowdSec decisions enforced at firewall in <5 seconds via LAPI bouncer
IDS rule coverage	40,000+ rules across Suricata and Snort (Emerging Threats, Snort Community, Talos)
Community intelligence	CrowdSec shares threat data with global network; >1M malicious IPs in feed
NetFlow visibility	pfSense, OPNsense, Cisco R1/R2/R3, Palo Alto all exporting to ntopng (192.168.1.48:2056)
Protocol metadata	Zeek captures full L7 metadata across prod_lan, lab_lan1, lab_lan2 (AF_PACKET cluster, 3 workers)
Log retention	90 days in Splunk/Elastic; 30 days on local firewall storage
Incident response	Documented playbooks for DDoS, brute force, lateral movement, ransomware

Network Firewall/Router Architecture

High-Availability pfSense Cluster

Deployment Overview

Two pfSense virtual machines operate in an active/passive high-availability configuration using CARP (Common Address Redundancy Protocol). The primary node synchronizes all configuration and state information to the secondary via a dedicated SYNC interface. In the event of failure, CARP provides sub-second failover with minimal packet loss, ensuring uninterrupted perimeter protection. Both nodes enforce default-deny firewall policies, NAT rules, VPN termination, and IDS/IPS inspection.



Security Impact

- Continuous perimeter protection even during maintenance or node failure
- Stateful failover preserves active connections, preventing session drops
- Inline Suricata/Snort inspection blocks malicious traffic at the edge
- Centralized logging feeds Splunk for correlation with internal telemetry

- VPN termination provides encrypted remote access without exposing internal networks

Deployment Rationale

High-availability firewalls are standard in enterprise networks where downtime directly impacts business operations. This deployment mirrors production-grade designs using redundant nodes, synchronized configuration, and automated failover. It demonstrates proficiency with CARP, state synchronization, multi-WAN routing, and perimeter-level security enforcement.

Architecture Principles Alignment

Defense in Depth: Redundant perimeter firewalls ensure continuous enforcement of ACLs, NAT, and IDS/IPS

Secure by Design: Default-deny rules, TLS-secured VPNs, and synchronized configurations

Zero Trust: Remote access requires identity verification; no implicit trust in network location

- Cluster Configuration

Node Role	Management IP	CARP VIP	State Sync
pfSense-Primary	192.168.100.2/24	192.168.100.1/24	Master
pfSense-Secondary	192.168.100.3/24	192.168.100.1/24	Backup
Sync Network	10.10.0.0/24	Dedicated	xmlrpc

Interface Design

- WAN(Prod_LAN) - Eth0
- LAN - WIFI bridge
- Sync - virtual interface for HA sync
- PIA_NY - VPN for outbound traffic
- PIA_CAN_MONT - VPN for outbound traffic
- TSCALE - Mesh VPN for remote access
- LAN2 - virtual interface
- External LAN – virtual interface

Interfaces			
WAN	↑	10Gbase-T <full-duplex>	192.168.1.253
LAN	↑	10Gbase-T <full-duplex>	192.168.100.2
SYNC	↑	10Gbase-T <full-duplex>	10.10.0.2
LAN2	↑	10Gbase-T <full-duplex>	192.168.200.2
EXTLAN	↑	10Gbase-T <full-duplex>	192.168.2.2
PIA_NY	↑		10.36.1
PIA_CAN_MONT	↑		10.10.
TSCALE	↑		n/a

Interface	Physical/Virtual	Network	Purpose
Prod_LAN	vtnet0	192.168.1.253/24	Upstream gateway to ISP router
Lab_LAN1	vtnet1 (bridge)	192.168.100.2/24	Primary lab network
SYNC	vtnet2	10.10.0.2/24	HA state synchronization
PIA_NY	ovpnc1	(Dynamic)	VPN egress - New York endpoint
PIA_CA_MONT	ovpnc2	(Dynamic)	VPN egress - Montreal endpoint
TSCALE	tailscale0	(Dynamic /32)	WireGuard mesh VPN for remote access
Lab_LAN2	vtnet3	192.168.200.2/24	Kubernetes cluster network

EXT_LAN	vtnet4	192.168.2.2/24	External lab services (DMZ-style)
----------------	--------	----------------	-----------------------------------

Traffic Flow Architecture:

- Default Route: LAN traffic (192.168.100.0/24) → PIA VPN → Internet
- Policy-Based Routing: Selective traffic bypass for latency-sensitive apps
- VPN Failover: Automatic failover between PIA_NY and PIA_CA_MONT on tunnel failure
- Kill Switch: Floating rule blocks LAN egress if all VPN tunnels are down

Security Enhancement Packages

pfBlockerNG - IP Reputation & Geofencing

Purpose: Network-layer blocking of malicious IPs and geographic regions

Configuration:

- Blocklists: 15+ curated feeds (Emerging Threats, Spamhaus, Abuse.ch)
- Update Frequency: Hourly refresh of threat intelligence feeds
- Geo-blocking: Block inbound from high-risk countries (configurable whitelist)
- Integration: Feeds alias tables used in firewall rules
- Use Case: Prevent C2 callbacks, block known botnets, reduce attack surface

Suricata IDS/IPS

Deployment: Active on WAN and LAN interfaces (both pfSense nodes)

Mode: Inline IPS with legacy blocking (balances performance vs. protection)

Rulesets:

- Emerging Threats Open (ET Open) - 40,000+ signatures
- Suricata Community Rules
- Custom local rules for lab-specific threat patterns

Configuration:

- Action: Drop + Alert on HIGH/CRITICAL severity events
- Performance: Disabled CPU-intensive rules for lab environment constraints
- Logging: JSON output forwarded to Splunk and Elastic via syslog-ng

Use Case: Real-time detection of exploits, malware, and lateral movement attempts

Snort IDS/IPS

Deployment: Active on PIA VPN interfaces (monitors encrypted tunnel egress)

Mode: Inline IPS for outbound traffic inspection

Rulesets:

- Snort Community Rules
- Talos Intelligence Registered User Rules
- Custom rules for data exfiltration patterns

Rationale:

While Suricata monitors north-south and east-west traffic, Snort provides additional coverage on VPN tunnels where traffic exits the lab. This dual-engine approach catches threats that might evade a single detection system.

CrowdSec - Behavioral Threat Intelligence

Architecture: Remediation Bouncer receives block decisions via LAPI, enforces at firewall

OPNsense Microsegmentation Firewall
Deployment Overview



A standalone OPNsense VM provides an additional security boundary for sensitive lab assets. Positioned behind the pfSense perimeter, it enforces microsegmentation policies, isolates high-value systems, and applies independent firewall rules, IDS/IPS policies, and access controls.

Security Impact

- Prevents lateral movement into sensitive subnets
- Independent policy engine ensures compromise of pfSense does not expose protected assets
- Additional IDS/IPS layer increases detection coverage
- Segmented logging improves visibility into east-west traffic

Deployment Rationale

Microsegmentation is a core zero-trust principle used in enterprise environments to isolate critical systems. Deploying OPNsense as a “firewall within a firewall” demonstrates layered security design, redundancy, and compartmentalization of trust domains.

Architecture Principles Alignment

Defense in Depth: Independent firewall layer behind pfSense perimeter

Secure by Design: Segmented networks, isolated rule sets, and dedicated IDS/IPS

Zero Trust: No internal subnet is implicitly trusted; access requires explicit policy

Status	Interface	Device	VLAN	Link Type	IPv4
🟢	Prod_LAN (lan)	vtnet0		dhcp	192.168.1.201/24
🟢	ISO_LAN (wan)	vtnet1		static	10.20.0.254/24

Interface Configuration

Interface Name	Type	Network	Security Zone	Role
PROD_LAN	Physical (eth0)	192.168.1.0/24	Trusted	Uplink to production network; allows controlled ingress from ISO_LAN
ISO_LAN	Virtual (OPTx)	10.20.0.0/24	Restricted	Isolated segment for sensitive hosts; tightly scoped egress rules

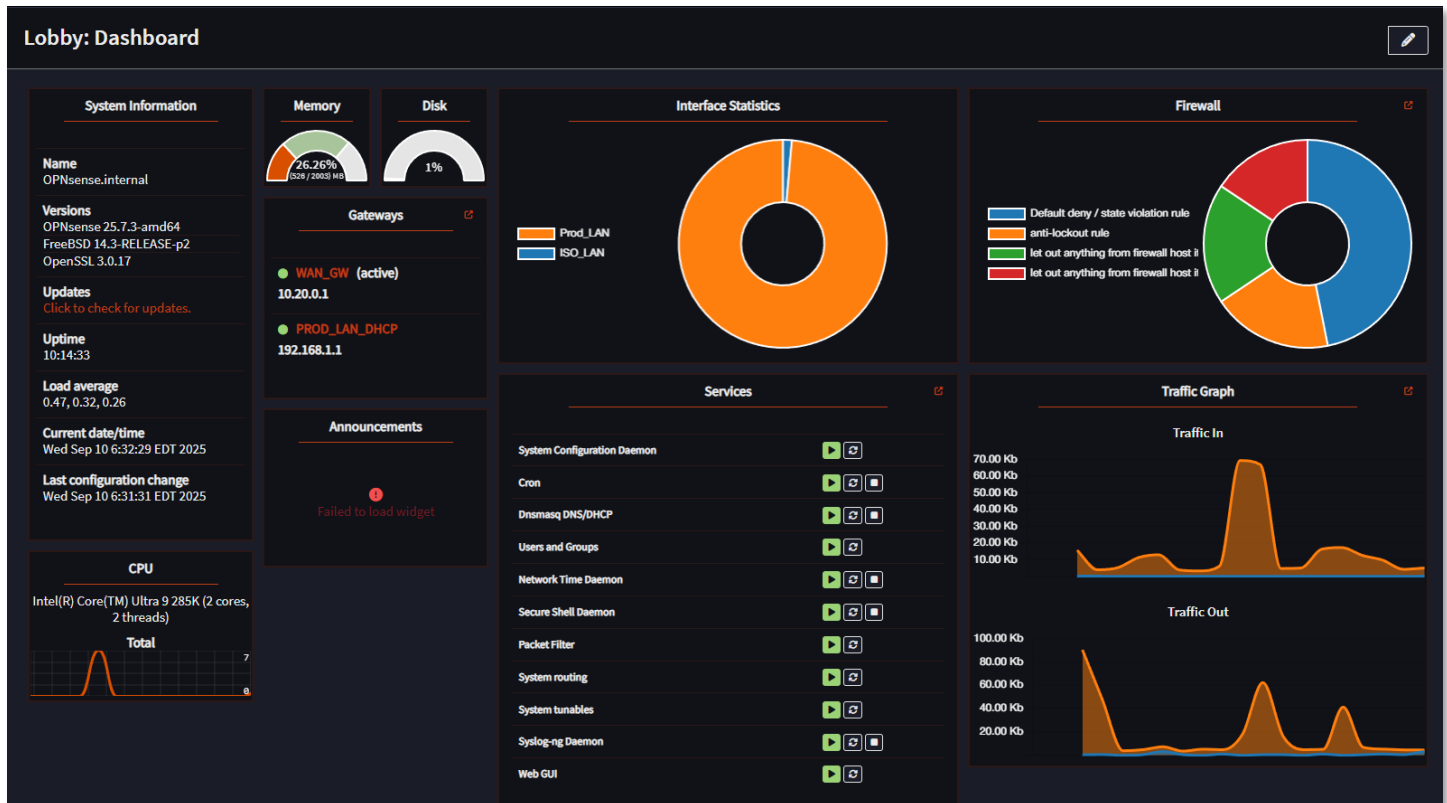
Protected Assets (ISO_LAN):

- Vulnerability management scanners (OpenVAS, Nessus)
- Configuration management (Ansible control node)

- Security logging infrastructure (Splunk forwarder)
- Certificate authority and PKI services
- Backup repositories with encrypted data

Firewall Policy Philosophy:

Default Deny with Explicit Allow - Zero trust model where all traffic is blocked unless explicitly permitted by rule. This inverts traditional firewall logic and ensures unknown traffic patterns are automatically rejected.



Fortinet Fortigate 30D Appliance Deployment Overview



The FortiGate 30D serves as a dedicated microsegmentation firewall protecting the management VLAN (192.168.3.0/24). Operating in unlicensed mode as an end-of-support device, it provides basic Layer 3/4 firewall functionality, SSL VPN access, and serves as a hands-on platform for FortiOS CLI and GUI administration. Despite lacking current threat intelligence updates, the appliance demonstrates enterprise firewall concepts including policy-based routing, SSL VPN configuration, and interface-based security zones.



Security Impact

- Enforces strict access controls to management subnet (VLAN 3)
- SSL VPN provides encrypted remote access to administrative interfaces
- Policy-based firewall rules segment management traffic from production workloads
- Hands-on experience with enterprise-grade firewall appliance management

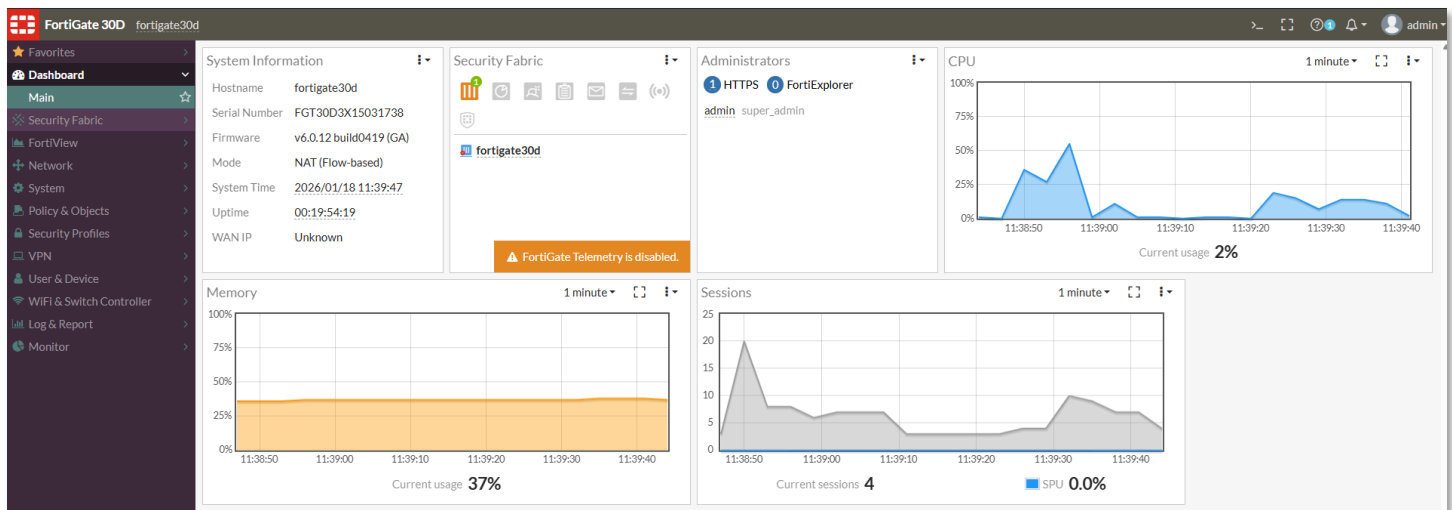
- Demonstrates defense-in-depth by adding physical firewall layer behind virtual pfSense/OPNsense

Deployment Rationale

Fortinet holds significant market share in enterprise network security, making FortiOS proficiency valuable for security roles. Operating an end-of-life appliance demonstrates understanding of legacy system risk management, compensating controls deployment, and resource-constrained security operations. The appliance serves educational purposes for Fortinet NSE certification preparation and FortiOS command-line interface skill development.

Architecture Principles Alignment

- **Defense in Depth:** Physical appliance provides hardware-based firewall enforcement independent of virtual infrastructure
- **Secure by Design:** Default-deny firewall policies; SSL VPN requires certificate-based authentication
- **Zero Trust:** Management VLAN access requires explicit firewall rules; no implicit trust between zones



Configuration Highlights

SSL VPN Configuration:

- Certificate-based authentication for remote administrative access
- Split-tunnel routing directs only management traffic through VPN
- FortiClient compatibility for Windows, macOS, Linux endpoints
- Per-user access policies restrict VPN access to authorized administrators

Firewall Policy Architecture (VLAN 3 Protection):

- Default-deny ingress from all external zones
- Explicit allow rules for SSH (port 22), HTTPS (port 443) from trusted source IPs
- Stateful inspection tracks connection state for allowed flows
- Logging enabled for all policy hits to support forensic analysis

Interface Configuration:

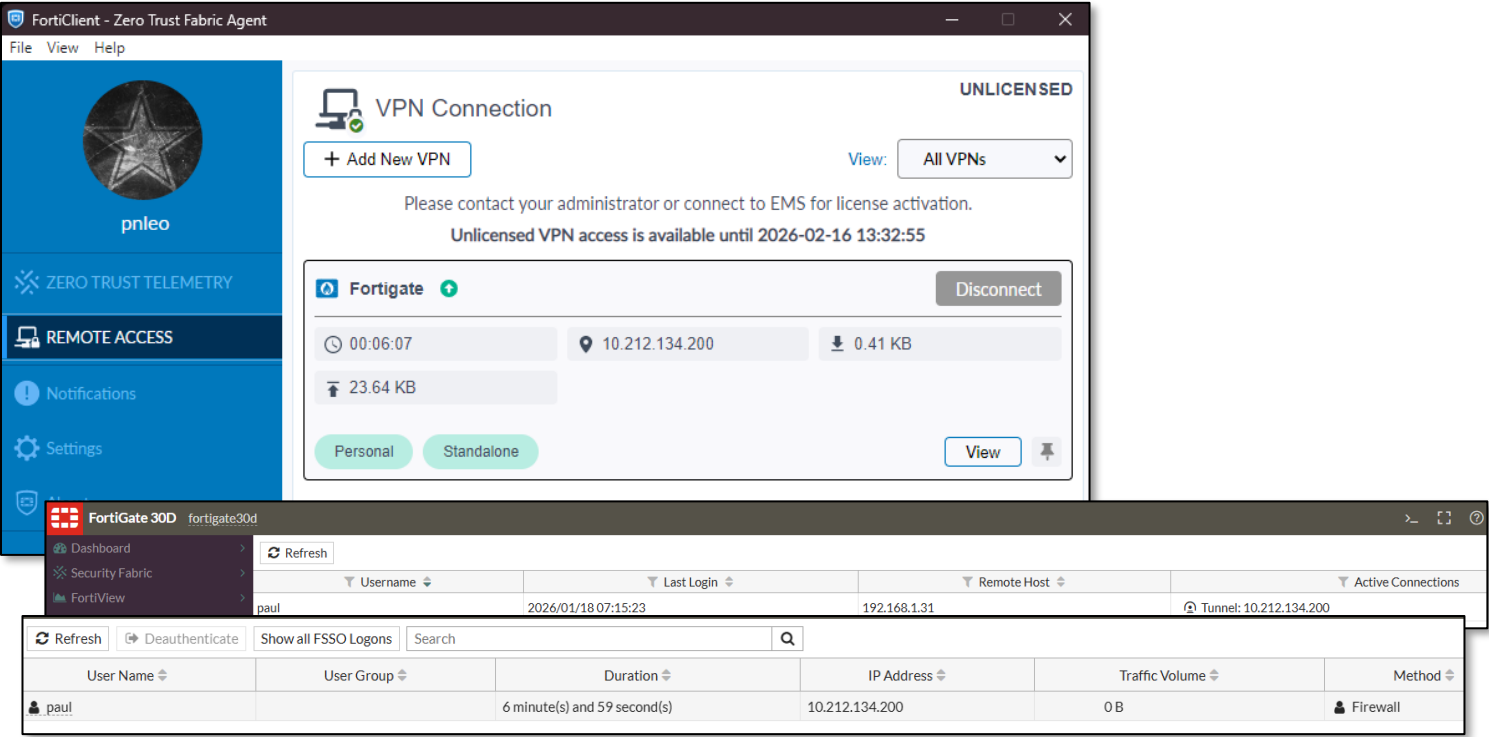
- Internal (port1): 192.168.3.1/24 - Management VLAN gateway
- External (port2): 192.168.1.x/24 - Uplink to production network
- DMZ (port3): Reserved for future isolated services deployment

FortiGate 30D WAN LAN 1234					
+ Create New SSID Edit Delete By TypeBy					
Status	Name	Members	IP/Netmask	Type	Access
Hardware Switch (1)					
	lan (Prod_LAN)	1234	192.168.1.99 255.255.255.0	Hardware Switch (4)	PING HTTPS SSH HTTP
Physical (1)					
	wan (ISO_LAN)		192.168.3.1 255.255.255.0	Physical Interface	PING HTTPS SSH HTTP

Address/Device Configuration

Name	Type	Details	Interface
Address 22			
Ansible Server	FQDN	ans.home.com	Prod_LAN (lan)
Elastic Server	FQDN	elastic.home.com	Prod_LAN (lan)
Ext_LAN	Subnet	192.168.2.0/24	Prod_LAN (lan)
FIREWALL_AUTH_PORTAL_ADDRESS	Subnet	0.0.0.0/0	
ISO_LAN	Subnet	192.168.3.0/24	ISO_LAN (wan)
Lab_LAN1	Subnet	192.168.100.0/24	Prod_LAN (lan)
Lab_LAN2	Subnet	192.168.200.0/24	Prod_LAN (lan)
Nessus Server	IP Range	192.168.100.5 - 192.168.100.5	Prod_LAN (lan)
OfficePC	FQDN	officepc.home.com	Prod_LAN (lan)
OpenVAS	FQDN	vas.home.com	Prod_LAN (lan)
Pihole	FQDN	pihole.home.com	Prod_LAN (lan)
Pihole_bk	FQDN	piholebk.home.com	Prod_LAN (lan)
Prod_LAN	Subnet	192.168.1.0/24	Prod_LAN (lan)
Prometheus Server	FQDN	prom.home.com	Prod_LAN (lan)
SSLVPN_TUNNEL_ADDR1	IP Range	10.212.134.200 - 10.212.134.210	SSL-VPN tunnel interface (ssl.root)
StepCA Server	FQDN	stepca.home.com	Prod_LAN (lan)
Traefik Server	IP Range	192.168.1.247 - 192.168.1.247	Prod_LAN (lan)
Wazuh Server	FQDN	wazuh.home.com	Prod_LAN (lan)
Web/Syslog Server	FQDN	web.home.com	Prod_LAN (lan)
all	Subnet	0.0.0.0/0	
iPad Pro	IP Range	192.168.1.194 - 192.168.1.194	Prod_LAN (lan)
none	Subnet	0.0.0.0/32	
Address Group 1			
DNS Servers	Address Group	Pihole Pihole_bk	Prod_LAN (lan)

SSL VPN



Use Cases

- Fortinet NSE certification lab environment
- FortiOS CLI command practice and automation scripting
- SSL VPN troubleshooting and configuration testing
- Firewall rule optimization and policy analysis
- Vendor-neutral firewall concepts demonstration

Limitations & Compensating Controls

Due to end-of-support status:

- No current threat intelligence updates - Compensated by pfSense Suricata/Snort IDS/IPS
- No firmware updates available - Mitigated by restricting management VLAN exposure
- Limited UTM features - Supplemented by pfBlockerNG, CrowdSec, SafeLine WAF
- Educational use only - Not relied upon for production-critical security enforcement

Risk Acceptance Record — FortiGate 30D End-of-Life Hardware

Field	Detail
Risk ID	RISK-NET-001
Date	March 2026
Owner	Paul Leone
Asset	FortiGate 30D Physical Firewall (192.168.1.99)
Risk Statement	The FortiGate 30D reached end-of-support with Fortinet in Q4 2023. No firmware updates, security patches, or vendor support are available. Deployment of unsupported network security infrastructure introduces risk of unpatched vulnerabilities being exploited.
Risk Category	Technical — End-of-Life Hardware

Likelihood	Low — device is not internet-facing; management access restricted to 192.168.1.0/24 via ACL; not used as primary perimeter firewall
Impact	Medium — if compromised, attacker gains access to VLAN 3 (192.168.3.0/24) management segment; lateral movement constrained by pfSense ACLs
Inherent Risk Level	Medium
Compensating Controls	1. FortiGate is not the primary perimeter firewall — pfSense HA cluster handles all internet-facing traffic 2. Management access restricted to Prod_LAN subnet (192.168.1.0/24) via VTY ACL 3. VLAN 3 (192.168.3.0/24) isolated by pfSense inter-VLAN ACLs — no direct path to production services 4. FortiGate management interfaces are not exposed to internet or DMZ 5. All FortiGate traffic is logged and forwarded to SIEM for anomaly detection 6. CrowdSec bouncer not deployed on FortiGate — covered by upstream pfSense enforcement 7. Weekly vulnerability scanning (OpenVAS) monitors for active exploitation patterns on management interface
Residual Risk Level	Low — compensating controls reduce effective risk to acceptable level for lab environment
Acceptance Rationale	The FortiGate 30D serves a specific educational purpose: hands-on experience with enterprise FortiOS administration, SSL VPN configuration, and Fortinet NSE certification preparation. These skills are directly relevant to enterprise security roles. The hardware cost to replace this device exceeds the budget available for this lab environment. The risk is accepted given the compensating controls in place and the non-production, isolated nature of the lab.
Exceptions	This risk acceptance does not extend to: internet-facing deployment of the FortiGate management interface; use of the FortiGate as the primary perimeter firewall; or deployment in any production environment.
Review Date	January 2027 — reassess if hardware replacement becomes feasible or if active CVEs targeting FortiOS 5.x are published
Approval	Paul Leone — Lab Owner

Palo Alto PAN-OS KVM Virtual Firewalls

Note: PA-FW instances operate on evaluation licenses. Features requiring subscriptions (WildFire, URL Filtering, GlobalProtect, Threat Prevention) are functional during the evaluation period. Architecture and configuration demonstrate production-equivalent capabilities.

Deployment Overview

Two Palo Alto VM-Series firewalls deployed as KVM guests extend the security architecture with next-

generation firewall (NGFW) capabilities including App-ID, User-ID, and advanced threat prevention. The first instance (PA-FW DMZ-ISO, mgmt: 192.168.99.138) functions as the primary NGFW, providing zone enforcement across the DMZ (192.168.2.0/24), isolated LAN segment ISO_LAN1 (10.20.0.0/24), and the production network (Prod_LAN, 192.168.1.0/24). The second instance (PA-FW Site2, mgmt: 192.168.99.139) simulates a remote branch site (10.40.0.0/24) connected to the primary firewall via an IPSec site-to-site tunnel. Both VMs operate within the ISO-DMZ virtual router and integrate with the home.com Active Directory domain for identity-based policy enforcement.



Security Impact

- App-ID inspects traffic at Layer 7, blocking disallowed applications regardless of port or protocol
- User-ID maps Active Directory group membership to firewall policy, enabling identity-aware access control without per-host rules
- IPSec site-to-site tunnel (AES-256/SHA-1) simulates branch office connectivity and validates encrypted inter-site traffic flows
- NAT policies enforce strict address translation boundaries between DMZ, internal, and external zones
- Security profiles (AV, anti-spyware, URL filtering, WildFire) applied per-policy provide multi-layer inline threat inspection
- OSPF adjacencies with Cisco lab routers (R1, R2, R3) over a dedicated OSPF zone (10.30.0.4/29) validate dynamic routing in a mixed-vendor environment
- Netflow export to NSM (192.168.1.48:2056) feeds network traffic visibility into the observability stack

Deployment Rationale

Palo Alto Networks holds a leading position in enterprise NGFW deployments. Operating VM-Series on KVM demonstrates platform-agnostic deployment and validates key NGFW differentiators: application-layer enforcement, identity integration, and advanced threat prevention. The dual-VM topology with IPSec interconnect mirrors hub-and-spoke branch architectures. Active Directory User-ID integration reflects production policy models where enforcement follows the user rather than the IP address.

Architecture Principles Alignment

- **Zero Trust:** Identity-based policies require explicit AD group membership for access; zone membership alone grants no implicit trust
- **Defense in Depth:** PA-FW sits inline between Prod_LAN, ISO_LAN1, and DMZ, adding a dedicated NGFW inspection layer independent of the pfSense/OPNsense perimeter
- **Least Privilege:** Differentiated group policies (VIPUserGroup, RestrictedUserGroup, Domain Users) enforce tiered access to internet resources, applications, and server segments

Interface and Zone Architecture

PA-FW DMZ-ISO operates with four routed Layer 3 interfaces plus virtual wire, loopback, and tunnel interfaces — all within the ISO-DMZ virtual router:

Interface	Zone	Address	Function
ethernet1/1	ISO_LAN1	10.20.0.138/24	Isolated LAN (inside)
ethernet1/2	DMZ	192.168.2.138/24	DMZ segment
ethernet1/3	Prod_LAN	192.168.1.138/24	Production LAN (outside/uplink)
ethernet1/4	OSPF	10.30.0.4/29	OSPF peering with lab routers
ethernet1/10-11	Prod-vWire	N/A	Virtual wire — transparent L2 inspection
ethernet1/24.10/20/30	L2-wired	N/A	L2 subinterfaces for VLAN switching
loopback.1	Site2-tunnel	192.168.255.138/32	IPSec tunnel source / OSPF router-ID
tunnel.1	GlobalProtect	N/A	GlobalProtect VPN termination
tunnel.40	Site2-tunnel	N/A	IPSec tunnel to Site2

PA-FW Site2 uses a two-interface topology:

Interface	Zone	Address	Function
-----------	------	---------	----------

ethernet1/1	site2-local	10.40.0.2/24	Local site network
ethernet1/2	Prod_LAN	192.168.1.139/24	Uplink / tunnel source
loopback.1	Site1-tunnel	192.168.255.139/32	IPSec tunnel source
tunnel.40	Site1-tunnel	N/A	IPSec tunnel to DMZ-ISO

IPSec Site-to-Site Tunnel

A site-to-site IPSec tunnel connects ISO_LAN1 (10.20.0.0/24) on PA-FW DMZ-ISO to the Site2 local network (10.40.0.0/24) on PA-FW Site2. The tunnel is sourced from loopback.1 on each device (192.168.255.138 and 192.168.255.139), decoupling the IKE endpoint from physical interface addressing.

- Phase 1 (IKEv1 Main Mode): AES-256-CBC, SHA-1, DH Group 2, 8-hour lifetime, pre-shared key authentication.
- Phase 2 (ESP tunnel): AES-256-CBC, SHA-1, no PFS, 8-hour lifetime, proxy IDs 10.20.0.0/24 ↔ 10.40.0.0/24. Security policies on both devices permit bidirectional IPSec traffic between protected subnets. Loopback keepalive rules (loopback-allow-in, loopback-allow-out) maintain health monitoring between the 192.168.255.x endpoints.

Name	Status	Type	IKE Gateway/Satellite				Tunnel Interface				
			Interface	Local IP	Peer IP	Status	Interface	Virtual Router	Virtual System	Security Zone	Status
Site2-IPSec	Tunnel Info	Auto Key	loopback.1	Loopback1-192.168.255.138	192.168.255.139	IKE Info	tunnel.40	ISO-DMZ (Show Routes)	vsys1	Site2-tunnel	

NAT Configuration

Two NAT policies manage address translation for DMZ-hosted services and outbound DMZ access.

- Destination NAT — Outside-Access-to-BentoPDF:** Inbound traffic from Prod_LAN destined to 192.168.1.138 (PA-FW outside interface) is translated to DMZ server 192.168.2.12. The corresponding security policy permits the translated flow with WildFire, AV (Custom1), and strict anti-spyware profiles applied.
- Source NAT — DMZ-to-Outside-NAT:** Outbound traffic from the DMZ zone is dynamically translated to the PA-FW Prod_LAN interface address (192.168.1.138) using dynamic IP-and-port (NAPT), providing DMZ hosts internet access while blocking direct inbound connections.

Name	Tags		Original Packet						Translated Packet		
			Source Zone	Destination Zone	Destination Interface	Source Address	Destination Address	Service	Source Translation	Destination Translation	
1 Outside-Access-to-BentoPDF	none		Prod_LAN	Prod_LAN	ethernet1/3	any	192.168.1.138	any	none	address: BentoPDF	
2 DMZ-to-Outside-NAT	none		DMZ	Prod_LAN	ethernet1/3	any	any	any	dynamic-ip-and-port	none	

2 NAT-BentoPDF	none	universal	Prod_LAN	any	any	any	DMZ	192.168.1.138	any	any	Allow	
3 DMZ-Access-to-Outside	none	universal	DMZ	any	any	any	Prod_LAN	any	any	application-default	Allow	

Active Directory Integration (User-ID)

PA-FW DMZ-ISO integrates with the home.com Active Directory domain (dc01.home.com, 192.168.1.152) via LDAP on port 389 using service account pa-svc@home.com. User-ID maps authenticated domain users and group memberships to source-user fields in security policy, enabling identity-based enforcement independent of IP address.

Several AD global security groups are defined for policy assignment:

- VIPUserGroup** — Permits expanded application set including streaming media and executive internet access
- RestrictedUserGroup** — Explicitly denies netflix and youtube; URL filtering enforced

- **VPNGroup** — Controls GlobalProtect VPN access via allow-list
- **FirewallAdmins** – Controls who can administer the Palo Alto VMs
- **ServerAdmins** – controls access to various Microsoft servers
- **Monitoring-Server-Admins** – controls access to various monitoring servers

User identification is enabled on ISO_LAN1, DMZ, Prod_LAN, and OSPF zones.

	Name	Tags	Type	Zone	Address	User	HTTP Profile	Zone	Address	Application	Service	Action	Profile	Options
4	Restricted-Internet-Access	none	interzone	ISO_LAN1	any	lab\restrictedinternet RestrictedUserGroup	any	DMZ	any	netflix youtube	application-default	Deny		
5	MS-Teams-UC	none	universal	any	any	lab\domain users	any	any	any	ms-office365... ms-teams sharepoint-o... sql web-browsing	application-default	Allow		
6	RestrictDMZ-to-US-CAN-EU	dmz prod_LAN	universal	Prod_LAN	CA EU US	any	any	DMZ	any	any	any	Allow	none	
7	VIP-Internet-Access	internet	interzone	ISO_LAN1	any	lab\executive lab\vip-internet-access VIPUserGroup	any	DMZ Prod_LAN	any	google-base http-audio http-video netflix web-browsing youtube	application-default	Allow		
8	Firewall-Admin-Access	none	universal	Prod_LAN	any	lab\firewalladmins	any	DMZ ISO_LAN1	10.0.0.0-10.25...	any	any	Allow	none	
9	DMZ-Server-Admin-Access	none	universal	Prod_LAN	Internal Netwo...	lab\dnssadmins lab\monitoring-server-... lab\msserveradmins	any	DMZ	192.168.0.0-19...	any	any	Allow	none	

Security Policy Architecture

Policies are enforced via vsys1 rulebase using source-user (AD group), App-ID, and zone-based matching. Security profiles (AV Custom1, anti-spyware custom1 with botnet sinkhole, URL filtering custom1, basic file blocking, WildFire) are attached per-policy to permitted flows. See Firewall Policy Architecture section for representative rules.

Routing

The ISO-DMZ virtual router participates in OSPF with lab Cisco routers R1, R2, and R3 via ethernet1/4 (10.30.0.4/29). PA-FW advertises DMZ (192.168.2.0/24), ISO_LAN1

(10.20.0.0/24), and

loopback (192.168.255.138/32). Static routes handle the default gateway (0.0.0.0/0 via 192.168.1.1) and the Site2 tunnel (10.40.0.0/24 via tunnel.40). OSPF-learned routes from the lab routers provide access to management and other lab subnets without static configuration.

Virtual Router - ISO-DMZ							
Routing RIP OSPF OSPFv3 BGP Multicast BFD Summary Information							
Summary Area Interface Neighbor Virtual Link Virtual Neighbor							
3 items							
Neighbor Address	Neighbor Router Id	Local Address Binding	Area Id	Neighbor Priority	Remaining Lifetime	Status	Message
10.30.0.1	192.168.255.1	0.0.0.0	0.0.0.0	1	32	two way	0
10.30.0.2	192.168.255.2	0.0.0.0	0.0.0.0	1	33	full	0
10.30.0.3	192.168.255.3	0.0.0.0	0.0.0.0	1	34	full	0

Virtual Router - ISO-DMZ

Routing RIP OSPF OSPFv3 BGP Multicast BFD Summary Information

Route Table Forwarding Table Static Route Monitoring

Route Table ☒ Unicast ☐ Multicast Display Address Family IPv4 and IPv6

20 items

Destination	Next Hop	Metric	Weight	Flags	Age	Interface
0.0.0.0/0	192.168.1.1	10		A S		ethernet1/3
10.20.0.138/32	0.0.0.0	0		A H		
10.30.0.0/29	0.0.0.0	10		Oi	82368	ethernet1/4
10.30.0.0/29	10.30.0.4	0		A C		ethernet1/4
10.30.0.4/32	0.0.0.0	0		A H		
10.40.0.0/24	0.0.0.0	10		A S		tunnel.40
10.40.0.1/32	0.0.0.0	0		A H		
192.168.1.0/24	10.30.0.1	11		Oi	82368	ethernet1/4
192.168.1.0/24	192.168.1.138	0		A C		ethernet1/3
192.168.1.138/32	0.0.0.0	0		A H		
192.168.2.0/24	0.0.0.0	10		Oi	80757	ethernet1/2
192.168.2.0/24	192.168.2.138	0		A C		ethernet1/2
192.168.2.138/32	0.0.0.0	0		A H		
192.168.3.0/24	10.30.0.2	11		A Oi	82368	ethernet1/4
192.168.100.0/24	10.30.0.1	11		A Oi	82368	ethernet1/4
192.168.200.0/24	10.30.0.1	11		A Oi	82368	ethernet1/4
192.168.255.1/32	10.30.0.1	11		A Oi	82368	ethernet1/4
192.168.255.2/32	10.30.0.2	11		A Oi	82368	ethernet1/4
192.168.255.3/32	10.30.0.3	11		A Oi	82368	ethernet1/4
192.168.255.138/32	0.0.0.0	0		A H		

Refresh Active, ?loose, Cconnect, Hhost, Sstatic, ~internal, Rrip, O:OSPF, B:bgp, Oi:OSPF intra-area, Oo:OSPF inter-area, O1:OSPF ext-type-1, O2:OSPF ext-type-2 E:ECMP

Additional Capabilities

- Virtual Wire (L2 Inline Inspection):** ethernet1/10 and ethernet1/11 form a virtual wire pair providing transparent Layer 2 inspection of Prod_LAN traffic without IP routing changes. VLAN10 subinterfaces enable per-VLAN policy enforcement. L2 switching on ethernet1/24 (VLAN10, VLAN20, VLAN30) with PVST+ extends policy enforcement to wired access segments.
- GlobalProtect VPN:** tunnel.1 provides GlobalProtect gateway termination in the GlobalProtect zone with User-ID awareness. VPNGroup membership controls access.
- Threat Prevention:** Custom profiles applied per-policy — AV Custom1 (FTP/POP3 drop, IMAP alert), anti-spyware custom1 (botnet sinkhole against PAN default DNS lists, reset-both on botnet category), URL filtering, and basic file blocking. WildFire sandbox analysis applied as default on all permitted flows.
- Role-Based Administration:** Four admin accounts: superuser (admin, paul), device admin (ansible — Ansible automation integration), and Network Admin custom role (paul-network — read-only CLI, full monitor/log WebUI access).

Firewall Policy Architecture

Deployment Overview

The lab implements a four-platform firewall architecture (pfSense, OPNsense, FortiGate, Palo Alto PAN-OS) using zone-based segmentation with zero-trust principles. Each VLAN and network segment operates as an isolated security zone with explicit allow rules — no implicit trust between networks. pfSense/OPNsense and FortiGate rules are deployed directionally on ingress interfaces. Palo Alto policies are enforced via

vsys1 rulebase with bidirectional zone-pair matching augmented by App-ID application identification and User-ID AD group membership.

Security Impact

- Zone-based segmentation prevents lateral movement between network tiers
- Default-deny policies block unauthorized traffic at all zone boundaries
- Palo Alto App-ID enforces application control at Layer 7 independent of port or protocol
- User-ID group policies ensure access decisions follow the identity, not the IP address
- IPSec tunnel policies on PA-FW enforce encrypted path enforcement between sites at the firewall policy layer
- Alias-driven rule definitions on pfSense/OPNsense/FortiGate enable rapid updates without rule rewrites
- Comprehensive logging across all platforms feeds SOC visibility and threat correlation

Deployment Rationale

Enterprise networks rely on zone-based firewalls to enforce trust boundaries between segments (DMZ, production, management). The addition of Palo Alto NGFW introduces application-layer and identity-layer controls that traditional stateful firewalls cannot replicate — App-ID replaces port-based rules, User-ID eliminates the need for IP-to-user mapping tables, and security profiles apply inline threat inspection consistently across all permitted flows.

Architecture Principles Alignment

- **Defense in Depth:** Four independent policy engines with overlapping enforcement; Palo Alto adds App-ID and User-ID layers on top of pfSense/OPNsense stateful inspection
- **Secure by Design:** Default-deny baseline with explicit allow rules across all platforms; automated threat feed integration
- **Zero Trust:** Cross-zone traffic requires explicit authorization; Palo Alto policies additionally require AD group membership for identity-sensitive rules

Policy Framework

Directional Rule Placement (*pfSense/OPNsense/FortiGate*): Rules apply on the ingress interface where traffic enters the firewall, ensuring deterministic packet flow, predictable state table creation, and consistent logging.

Zone-Pair Matching (Palo Alto): Policies match on source zone, destination zone, source address, destination address, source-user (AD group), and application (App-ID). Security profiles are attached per-rule for inline AV, anti-spyware, URL filtering, and WildFire analysis.

Alias Architecture

Host, network, and service definitions use reusable aliases:

- **Host Groups:** WEB_SERVERS, SOC_APPS, K3S_NODES, ADMIN_HOSTS, DNS_SERVERS, PROXY_HOST
- **Network Groups:** INTERNAL_SUBNETS, ISO_SUBNETS, LAB_NETWORKS
- **Service Groups:** WEB_PORTS, SOC_PORTS, K3S_PORTS, ADMIN_PORTS, WAZUH_PORTS

Aliases enable single-point updates—adding a new web server requires updating WEB_SERVERS alias, not 15+ individual rules.

Logging and Detection

All security-relevant rules generate logs tagged for SIEM ingestion (Splunk/Elastic/Wazuh). Suricata/Snort rules normalize alerts across platforms for consistent threat detection and correlation.

Ruleset Summary

Total Rules Deployed: 133 rules across three platforms

Rule Distribution by Platform:

- **FortiGate (Management Firewall):** 16 rules protecting Management and ISO_LAN2 192.168.3.0/24 subnet
- **OPNsense (Microsegmentation):** 23 rules isolating sensitive ISO_LAN (10.20.0.0/24)
- **pfSense (Edge/Core):** 94 rules managing perimeter, inter-VLAN routing, VPN policy

Rule Categories:

- **Cross-Zone Access:** 78 rules (59%) - traffic between security zones
- **Security Controls:** 18 rules (14%) - CrowdSec blocks, bogon filters, CARP HA
- **Diagnostics:** 12 rules (9%) - ICMP/traceroute for network troubleshooting
- **Management Access:** 15 rules (11%) - administrative SSH/HTTPS to infrastructure
- **Monitoring/EDR:** 10 rules (8%) - Wazuh agents, Prometheus metrics, log forwarding

Representative Rules

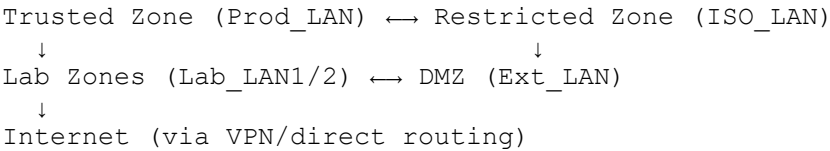
Platform	Source	Destination	Application / Service	Source User	Action	Logged
pfSense	Ext_LAN	Web_Server	TCP 80, 443, 8080	—	Allow	Yes
pfSense	ANY	crowdsec_blocklists	ANY	—	Drop	No
pfSense	Lab_LAN2	Elastic_Server	TCP 8220, 9200, 5044	—	Allow	Yes
FortiGate	ISO_LAN	DNS_Servers	UDP 53	—	Allow	Yes
FortiGate	ISO_LAN	Wazuh_Server	UDP 1514, TCP 1515	—	Allow	Yes
OPNsense	Admin_Hosts	ISO_LAN	TCP 22, 80, 443, 8080	—	Allow	Yes
Palo Alto	ISO_LAN1	Site2-tunnel	Any (IPSec proxy: 10.20.0.0/24 → 10.40.0.0/24)	Any	Allow	Yes
Palo Alto	Site2-tunnel	ISO_LAN1	Any (IPSec proxy: 10.40.0.0/24 → 10.20.0.0/24)	Any	Allow	Yes
Palo Alto	ISO_LAN1	DMZ, Prod_LAN	netflix, youtube	RestrictedUserGroup (AD)	Deny	Yes
Palo Alto	ISO_LAN1	DMZ, Prod_LAN	google-base, http-video, web-browsing	VIPUserGroup (AD)	Allow + Profiles	Yes
Palo Alto	Any	Any	ms-teams, O365,	Domain Users (AD)	Allow + File Block	Yes

			SharePoint, ssl			
Palo Alto	Prod_LAN	DMZ	Any → DNAT 192.168.2.12	Any	Allow + WildFire/A V	Yes

Security Enforcement Highlights:

- **CrowdSec Integration:** 12 block rules across pfSense/OPNsense/FortiGate enforce behavioral threat intelligence
- **Bogon Filtering:** Reserved/private IP ranges blocked on WAN-facing interfaces
- **Default Deny:** Implicit deny-all terminates each interface ruleset and Palo Alto zone-pair rulebase
- **VPN Kill Switch:** pfSense floating rules block LAN egress when VPN tunnels fail
- **Palo Alto IPSec Enforcement:** Tunnel security policies enforce that inter-site traffic traverses the encrypted path; direct routing between 10.20.0.0/24 and 10.40.0.0/24 outside the tunnel is denied
- **Identity-Driven Deny:** Palo Alto RestrictedUserGroup rules enforce application-level restrictions based on AD group membership at the firewall layer, independent of endpoint controls

Zone Trust Model:



Cross-zone traffic requires explicit firewall rules with service-level restrictions. No zone has blanket access to another—even administrative subnets require per-service authorization.

Configuration Examples

pfSense Rule Configuration(Prod_LAN Interface)

		0/3 KiB	IPv4 UDP	Subnets_ISO	*	Subnets_Prod_Lab_Ext	Linux_Traceroute_Ports	*	none	Passthrough - Allow Linux Host Traceroute
		0/7 KiB	IPv4 ICMP any	Admin_hosts	*	Subnets_Prod_Lab_Ext	*	*	none	OfficePC/iPad Ping testing to Subnets
		0/0 B	IPv4 ICMP any	Admin_hosts	*	Subnets_ISO	*	*	none	OfficePC/iPad Ping testing to Subnets
		0/0 B	IPv4 TCP	Admin_hosts	*	Subnets_ISO	Admin_ports	*	none	OfficePC/iPad access to ISO Subnets
		0/0 B	IPv4 TCP	192.168.1.89	*	Lab_Network2	SOC_Ports	*	none	Cortex to SOC application access
		0/0 B	IPv4 TCP	Prod_Network	*	192.168.200.41	Shuffle_Ports	*	none	Shuffle Access for Prod_LAN
		5/888.01 MiB	IPv4 TCP	192.168.1.126	*	Subnets_Prod_Lab_Ext	checkmk_Ports	*	none	Checkmk Agent Access
		2/77.93 MiB	IPv4 TCP/UDP	Admin_hosts	*	Subnets_Prod_Lab_Ext	Admin_ports	*	none	OfficePC/iPad access to all Internal Subnets
		1/39.37 MiB	IPv4 TCP	Traefik_Server	*	Traefik_Services	Traefik_Ports	*	none	Traefik Access to Backend Services
		0/1 KiB	IPv4 UDP	Prod_Network	*	Subnets_Prod_Lab_Ext	Linux_Traceroute_Ports	*	none	Allow Linux Host Traceroute
		4/135.85 MiB	IPv4 TCP	192.168.1.126	*	Portainer_Agents	Portainer_Ports	*	none	Portainer Manager to Agent Access
		16/68.55 MiB	IPv4 TCP	Admin_hosts	*	192.168.100.5	8834	*	none	Admin Host Access to Nessus WebUI
		11/711.08 MiB	IPv4 TCP/UDP	192.168.1.166	*	Subnets_Prod_Lab_Ext	Vuln_Scan_Ports	*	none	OpenVAS Scanning of Internal networks
		0/0 B	IPv4 ICMP any	192.168.1.166	*	Subnets_Prod_Lab_Ext	*	*	none	OpenVAS ICMP to Internal networks
		0/0 B	IPv4 ICMP any	192.168.1.166	*	Subnets_ISO	*	*	none	OpenVAS ICMP to ISO networks
		0/0 B	IPv4 TCP/UDP	192.168.1.166	*	Subnets_ISO	Vuln_Scan_Ports	*	none	OpenVAS Scanning of ISO networks
		0/471 KiB	IPv4 TCP	Prod_Network	*	192.168.100.51	443 (HTTPS)	*	none	ACME Clients to StepCA (HTTPS)
		8/64.77 MiB	IPv4 TCP	Prod_Network	*	PatchMon_Servers	PatchMon_Ports	*	none	PatchMon Server Access for both Agent Reg and UI
		0/3.98 MiB	IPv4 TCP	Subnets_ISO	*	PatchMon_Servers	PatchMon_Ports	*	none	Passthrough - PatchMon Server Access for both Agent Reg and UI

VPN Floating Rule Configuration

Firewall / Rules / Floating

Floating Tailscale PROD_LAN LAB_LAN1 SYNC LAB_LAN2 EXT_LANDMZ PIA_NY PIA_CAN_MONT OpenVPN

Rules (Drag to Change Order)

	States	Interfaces	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Action
		0/0 B	PROD_LAN	IPv4 *	*	*	*	*	none		VPN killswitch	

VPN Kill Switch Details:

This critical floating rule ensures that if the PIA VPN tunnel drops (failure, misconfiguration, or provider outage), traffic from LAN/LAN2 networks cannot egress through the unencrypted Verizon WAN connection. The rule triggers when the gateway is not one of the PIA interfaces, immediately blocking traffic to prevent IP leakage or unintended cleartext transmission.

pfSense Log Examples

✓	2026-01-30 06:49:32.094757-05:00	PROD_LAN	Admin Host Access to Nessus WebUI (1769728631)	i 192.168.1.31:55542	i 192.168.100.5:8834	TCP:S
✓	2026-01-30 06:49:32.094764-05:00	LAB_LAN1	let out anything IPv4 from firewall host itself (1000009913)	i 192.168.1.31:55542	i 192.168.100.5:8834	TCP:S
✓	2026-01-30 06:49:33.102053-05:00	PROD_LAN	Elastic Agent Enrollment and Data Ingestion to FL... (1759599463)	i 192.168.1.126:43956	i 192.168.200.8:9200	TCP:S
✓	2026-01-30 06:49:33.102074-05:00	LAB_LAN2	let out anything IPv4 from firewall host itself (1000009913)	i 192.168.1.126:43956	i 192.168.200.8:9200	TCP:S
✓	2026-01-30 06:49:33.102081-05:00	PROD_LAN	Checkmk Agent Access (1769649791)	i 192.168.1.126:49978	i 192.168.200.8:6556	TCP:S
✓	2026-01-30 06:49:33.102088-05:00	LAB_LAN2	let out anything IPv4 from firewall host itself (1000009913)	i 192.168.1.126:49978	i 192.168.200.8:6556	TCP:S
✓	2026-01-30 06:49:34.099024-05:00	PROD_LAN	OfficePC/iPad access to all Internal Subnets (1761650001)	i 192.168.1.31:57908	i 192.168.100.1:443	TCP:S
✓	2026-01-30 06:49:34.099204-05:00	PROD_LAN	PatchMon Server Access for both Agent Reg and UI (1765979966)	i 192.168.1.181:49506	i 192.168.200.35:3000	TCP:S
✓	2026-01-30 06:49:34.099210-05:00	LAB_LAN2	let out anything IPv4 from firewall host itself (1000009913)	i 192.168.1.181:49506	i 192.168.200.35:3000	TCP:S
✓	2026-01-30 06:49:35.097825-05:00	LAB_LAN1	Route out PIA CA Mont (1756464426)	i 192.168.100.15:6881	i 117.209.46.212:27937	UDP
✓	2026-01-30 06:49:35.097847-05:00	PROD_LAN	let out anything IPv4 from firewall host itself (1000009913)	i 192.168.100.15:6881	i 117.209.46.212:27937	UDP
✓	2026-01-30 06:49:39.093476-05:00	LAB_LAN2	DNS access for lab network (1757447681)	i 192.168.200.22:5208	i 192.168.1.126:53	UDP
✓	2026-01-30 06:49:39.093490-05:00	PROD_LAN	let out anything IPv4 from firewall host itself (1000009913)	i 192.168.200.22:5208	i 192.168.1.126:53	UDP
✓	2026-01-30 08:19:52.424297-05:00	LAB_LAN2	SOC application to Cortex access (1769648363)	i 192.168.200.21:38618	i 192.168.1.89:9002	TCP:S
✓	2026-01-30 08:19:52.424306-05:00	PROD_LAN	let out anything IPv4 from firewall host itself (1000009913)	i 192.168.200.21:38618	i 192.168.1.89:9002	TCP:S
✗	2026-02-01 08:09:17.779893-05:00	LAB_LAN2	block all other internal traffic from Lab_LAN2 intf (1769900583)	i 192.168.200.21:58525	i 192.168.1.89:9002	TCP:PA

OPNsense Rule Configuration

	Protocol	Source	Port	Destination	Port	Gateway	Schedule	Description
Automatically generated rules								
	IPv4 ICMP	ISO_LAN	*	Prod_Network, Lab_Networks, External_LAN	*	*	*	Test Ping/Traceroute to internal subnets
	IPv4 UDP	ISO_LAN	*	Prod_Network, Lab_Networks, External_LAN	Linux_Ports_for_Traceroute	*	*	Test Ping/Traceroute to internal subnets
	IPv4 ICMP	10.20.0.1/32	*	Prod_Network, This Firewall, ISO_LAN address, Prod_LAN address	*	*	*	Testing to Internal Subnets
	IPv4 TCP	ISO_LAN	*	Web_server, Proxy	web_ports	*	*	ISO LAN access to web server and proxy
	IPv4 *	ISO_LAN, This Firewall	*	DNS_Servers	*	*	*	ISO LAN access to DNS servers
	IPv4 TCP	ISO_LAN	*	192.168.1.25/32	22 (SSH)	*	*	ISO LAN access to Ansible Server
	IPv4 TCP	ISO_LAN	*	192.168.1.219/32	Wazuh_Ports	*	*	Wazuh Agent to Manager Access
	IPv4 TCP	ISO_LAN	*	192.168.200.39/32	3001	*	*	Patchmon agent
	IPv4 ICMP	*	*	This Firewall	*	*	*	
	IPv4 *	10.20.0.1/32	*	ISO_LAN address, Prod_LAN address	*	*	*	
	IPv4 TCP	Admin_Hosts	*	ISO_LAN	Admin_Ports	*	*	Admin Access to ISO_LAN
	IPv4 TCP	192.168.1.25/32	*	ISO_LAN	Ansible_Ports	*	*	Ansible SSH/Win access
	IPv4 TCP/UDP	192.168.1.166/32	*	ISO_LAN, Prod_LAN address	Vuln_Scan_Ports	*	*	OpenVAS access for Network/host scanning
	IPv4 *	This Firewall	*	*	*	*	*	
	IPv4 *	*	*	DNS_Servers	*	*	*	External dns servers
	IPv4 ICMP	Prod_Network, Lab_Networks, External_LAN	*	ISO_LAN	*	*	*	Ping tests
	IPv4 TCP/UDP	192.168.1.126/32	*	This Firewall, Prod_LAN address	9100	*	*	Prometheus metrics scrape
	IPv4 TCP/UDP	192.168.1.181	*	ISO_LAN	Uptime_Kuma_Ports	*	*	Uptime Kuma Monitoring of ISO LAN
	IPv4 IGMP	192.168.1.181/32	*	ISO_LAN	*	*	*	Uptime Kuma ICMP Monitoring of ISO LAN
	IPv4 *	This Firewall	*	Asus_Router	*	*	*	OPNsense to Asus Router
	IPv4 *	This Firewall	*	192.168.1.33/32	*	*	*	CrowdSec Access

FortiGate Rule Configuration

ID	Name	Source	Destination	Schedule	Service	Action	NAT	Security Profiles	Log
ISO_LAN (wan) → Prod_LAN (lan) 11									
19	Ping/Traceroute to Internal Network	ISO_LAN	Ext_LAN Lab_LAN1 Lab_LAN2 Prod_LAN	always	ALL_ICMP TRACEROUTE PING	✓ ACCEPT	✗ Disabled		✓ All
4	DNS Access for ISO_LAN	ISO_LAN	DNS Servers	always	DNS	✓ ACCEPT	✗ Disabled		✓ All
6	Syslog Access	ISO_LAN	Webserver	always	SYSLOG Web Access	✓ ACCEPT	✗ Disabled		UTM
7	Prometheus Metrics	ISO_LAN	Prometheus Server	always	prometheus	✓ ACCEPT	✗ Disabled		✓ All
8	Wazuh EDR Monitoring	ISO_LAN	Wazuh Server	always	Wazuh_Ports	✓ ACCEPT	✗ Disabled		UTM
10	Elastic Agent to Fleet Server	ISO_LAN	Elastic Server	always	Elastic Ports	✓ ACCEPT	✗ Disabled		UTM
17	R2 Access to external networks	r2	Lab_LAN1 Lab_LAN2 Prod_LAN	always	ALL	✓ ACCEPT	✗ Disabled		UTM
15	testing to prod_LAN	ISO_LAN	Prod_LAN	always	ALL_ICMP TRACEROUTE	✓ ACCEPT	✗ Disabled		✓ All
16	external web access	ISO_LAN	ubuntu repository	always	HTTP HTTPS	✓ ACCEPT	✓ Enabled	IPS default SSL certificate-inspection	✓ All
18	PatchMon Agent Access	ISO_LAN	PatchMon_Backend	always	PatchMon_Agent_Port	✓ ACCEPT	✗ Disabled		UTM
20	Route to pfSense	ISO_LAN	pfSense Prod_LAN	always	PING TRACEROUTE	✓ ACCEPT	✗ Disabled		UTM
Prod_LAN (lan) → ISO_LAN (wan) 7									
3	Allow MGMT to ISO_LAN	Admin_Hosts	ISO_LAN	always	ALL_ICMP HTTP HTTPS SSH Admin_Ports	✓ ACCEPT	✗ Disabled		✓ All
5	OpenVAS scanning	OpenVAS	ISO_LAN	always	Vuln_Scan_Ports	✓ ACCEPT	✗ Disabled		UTM
9	Ansible Provisioning	Ansible Server	ISO_LAN	always	Ansible_Ports	✓ ACCEPT	✗ Disabled		✓ All
11	StepCA/ACME Access to ISO_LAN	StepCA Server	ISO_LAN	always	HTTP HTTPS	✓ ACCEPT	✗ Disabled		✓ All
13	Nessus Scanner Access to ISO	Nessus Server	ISO_LAN	always	Vuln_Scan_Ports	✓ ACCEPT	✗ Disabled		UTM
14	Traefik Proxy Access	Traefik Server	ISO_LAN	always	Web Access	✓ ACCEPT	✗ Disabled		✓ All
21	Uptime Kuma Monitoring for ISO LAN	Uptime Kuma Server	ISO_LAN	always	PING Uptime_Kuma_Ports	✓ ACCEPT	✗ Disabled		UTM
SSL-VPN tunnel interface (ssl.root) → Prod_LAN (lan) 1									
2	VPN-users	all paul	none	always	ALL	✓ ACCEPT	✓ Enabled		✓ All
Implicit 1									
0	Implicit Deny	all	all	always	ALL	✗ DENY			✗ Disabled

Palo Alto Security Policies

Name	Tags	Type	Zone	Address	User	HTTP Profile	Zone	Address	Application	Service	Action	Profile
1 NAT-BentoPDF	none	universal	Prod_LAN	any	any	any	DMZ	192.168.1.138	any	any	Allow	
2 IPsec-ISO-to-Site2	none	universal	ISO_LAN1	10.20.0.0/24	any	any	Site2-tunnel	10.40.0.0/24	any	any	Allow	none
3 IPsec-Site2-to-ISO	none	universal	Site2-tunnel	10.40.0.0/24	any	any	ISO_LAN1	10.20.0.0/24	any	any	Allow	none
4 loopback-allow-out	none	universal	Site2-tunnel	192.168.255.138	any	any	any	192.168.255.139	any	any	Allow	none
5 loopback-allow-in	none	universal	any	192.168.255.139	any	any	Site2-tunnel	192.168.255.138	any	any	Allow	none
6 DMZ-Access-to-Outside	none	universal	DMZ	any	any	any	Prod_LAN	any	any	application-default	Allow	none
7 Restricted-Internet-Access	none	interzone	ISO_LAN1	any	lab/restrictedinternet	any	DMZ	any	netflix	application-default	Deny	
8 MS-Teams-UC	none	universal	any	any	RestrictedUserGroup	any	Prod_LAN	any	youtube	application-default	Allow	
					lab/domain users				ms-office365...			
									ms-teams			
									sharepoint-o...			
9 RestrictDMZ-to-US-CAN-EU	dmz prod_LAN	universal	Prod_LAN	CA	any	any	DMZ	any	any	any	Allow	none
				EU								
10 VIP-Internet-Access	internet	interzone	ISO_LAN1	any	lab/executive	any	DMZ	any	google-base	application-default	Allow	
					lab/vip-internet-access		Prod_LAN		http-audio			
					VIPUserGroup				http-video			
									netflix			
11 GlobalProtect-portal-access	none	universal	Prod_LAN	any	any	any	Prod_LAN	192.168.1.138	any	service-http	Allow	none
										service-https		
12 Firewall-Admin-Access	none	universal	Prod_LAN	any	lab/firewalladmins	any	DMZ	10.0.0.0-10.25...	any	any	Allow	none
13 DMZ-Server-Admin-Access	none	universal	Prod_LAN	Internal Netwo...	lab/dnsadmins	any	DMZ	any	any	any	Allow	none
					lab/monitoring-server...							
14 Deny-Direct-BentoPDF-Access	none	universal	any	any	any	any	DMZ	BentoPDF	any	any	Deny	none
15 allow admin access to all zones	none	universal	Prod_LAN	Admin Hosts	any	any	DMZ	10.0.0.0-10.25...	any	any	Allow	none
							ISO_LAN1	192.168.0.0-19...				
16 Allow Access to DNS Servers	dns	universal	DMZ	any	any	any	Prod_LAN	DNS Servers	dns	application-default	Allow	none
			ISO_LAN1									
17 Allow Elastic Agent access	logging	universal	ISO_LAN1	any	any	any	Prod_LAN	Elastic Server	any	Elastic TCP Ports	Allow	none
18 Allow Access to Prom Server	monitoring	universal	Prod_LAN	Prometheus Se...	any	any	DMZ	any	any	prometheus	Allow	none
			ISO_LAN1				ISO_LAN1					
19 Allow Chckmk Access	monitoring	universal	DMZ	any	any	any	Prod_LAN	Checkmk Server	any	Checkmk TCP Ports	Allow	none
			ISO_LAN1									
20 Allow Patchmon Access	monitoring	universal	DMZ	any	any	any	Prod_LAN	Patchmon Serv...	any	Patchmon TCP Ports	Allow	none
			ISO_LAN1									
21 Allow Uptime Kuma Access	monitoring	universal	Prod_LAN	Uptime Kuma ...	any	any	DMZ	any	Uptime Kuma	application-default	Allow	none
			ISO_LAN1				ISO_LAN1					
22 Allow Wazuh Agent Access	logging	universal	DMZ	any	any	any	Prod_LAN	Wazuh Server	any	Wazuh TCP Ports	Allow	none
			ISO_LAN1				ISO_LAN1					
23 Allow Ansible Access	automation	universal	Prod_LAN	Ansible Server	any	any	DMZ	any	any	Ansible Ports	Allow	none
			ISO_LAN1				ISO_LAN1					
24 Allow Access to Traefik Proxy	proxy	universal	DMZ	any	any	any	Prod_LAN	Traefik Proxy	any	service-http	Allow	none
			ISO_LAN1									
25 Allow Nessus Scanning Access	scanning	universal	Prod_LAN	Nessus Server	any	any	DMZ	any	ssl	application-default	Allow	none
							ISO_LAN1		tenable-nessus			
26 Prod_vWire-Out	none	universal	Prod-vWire-L...	any	any	any	Prod-vWire-egress	any	any	any	Allow	
27 Prod_vWire-To	none	universal	Prod-vWire-L...	any	any	any	Prod-vWire-egress	any	any	any	Allow	

Intrusion Detection/Prevention Solutions

Suricata Intrusion Detection/Prevention System on pfSense

Deployment Overview

Each pfSense node runs Suricata in inline IPS mode, inspecting four internal LAN interfaces. Suricata performs deep packet inspection, signature-based detection, and behavioral anomaly detection. Rule sets include Emerging Threats, custom local rules, and tuned signatures for lab-specific traffic patterns.



Interface Settings Overview			
Interface	Suricata Status	Pattern Match	Blocking Mode
☒ LAB_LAN1 (vtnet1)		AUTO	INLINE IPS
☐ PROD_LAN (vtnet0)		AUTO	INLINE IPS
☐ EXT_LANDMZ (vtnet4)		AUTO	INLINE IPS
☐ LAB_LAN2 (vtnet3)		AUTO	INLINE IPS

Security Impact

- Real-time blocking of known attack signatures
- Deep packet inspection identifies malicious payloads and protocol anomalies
- Custom rules detect lab-specific threats and reconnaissance
- Alerts forwarded to Elastic and Splunk for centralized correlation
- Inline mode prevents malicious traffic before it reaches internal systems

Deployment Rationale

Suricata is widely used in enterprise IDS/IPS deployments due to its performance, rule flexibility, and multi-threaded architecture. Running Suricata inline on pfSense mirrors production edge security designs and demonstrates proficiency with rule tuning, packet inspection, and IPS enforcement.

Architecture Principles Alignment

Defense in Depth: IDS/IPS layer reinforces firewall ACLs and WAF protections

Secure by Design: Inline blocking, updated rule feeds, and custom signatures

Zero Trust: All traffic inspected; no packet trusted without validation



Suricata block list Screenshot

Snort Intrusion Detection/Prevention System on pfSense

Deployment Overview



Snort runs in Legacy (IDS) mode on each pfSense node, monitoring PIA VPN interfaces for malicious traffic.

This provides an additional detection engine specifically focused on encrypted or tunneled traffic paths.

Services / Snort / Interfaces

Snort Interfaces

Global Settings

Updates

Alerts

Blocked

Pass Lists

Suppress

IP L

Interface Settings Overview

Interface	Snort Status	Pattern Match	Blocking Mode
☐ PIA_NY (ovpnc1)	✓ ↺ ⏸	AC-BNFA	LEGACY MODE
☐ PIA_CA_MONT (ovpnc2)	✓ ↺ ⏸	AC-BNFA	LEGACY MODE

Security Impact

- Detects threats traversing VPN tunnels
- Provides signature diversity alongside Suricata
- Alerts forwarded to Splunk for unified SOC visibility

Deployment Rationale

Running both Suricata and Snort mirrors enterprise SOC environments where multiple IDS engines provide overlapping detection coverage. This reduces blind spots and increases detection accuracy across encrypted or obfuscated traffic.

Architecture Principles Alignment

Defense in Depth: Dual IDS engines reduce reliance on a single detection method

Secure by Design: Custom updated rule sets

Zero Trust: VPN traffic inspected and validated; no implicit trust in encrypted tunnel

Custom Ruleset Architecture

Overview

In addition to the packaged rulesets provided by various sources, I've added custom Interface-specific Suricata and Snort rulesets deployed per subnet. Each ruleset addresses the security requirements of its associated network segment.

Rule Categories

- Linux/SSH Security Controls
- Reconnaissance & Scanning Detection
- Lateral Movement Prevention
- SMB/NetBIOS Hygiene
- Test & Validation Rules

Network Segments & Security Posture

Prod_LAN (192.168.1.0/24)

Role: Primary production network

Security Objectives:

- Block LAB/ISO → PROD lateral movement
- Detect reconnaissance and SSH abuse
- Enforce SMB protocol hygiene

Detection Coverage:

- SSH brute-force attacks (threshold-based)
- Privilege escalation keywords (sudo detection)
- Nmap OS fingerprinting
- Cross-segment port access (LAB→PROD high-risk ports)
- ISO network isolation violations
- SMBv1/NetBIOS legacy protocol usage
- Rule validation traffic

Lab_LAN1 (192.168.100.0/24)

Role: Primary development and testing environment

Security Objectives:

- Prevent LAB1 → PROD unauthorized access
- Detect internal reconnaissance activity
- Maintain ISO network isolation

Detection Coverage:

- SSH authentication abuse

- Privilege escalation indicators
- Network scanning (Nmap signatures)
- Cross-segment violations (LAB1→PROD)
- ISO→LAB1 boundary violations
- SMB/NetBIOS misuse

Lab_LAN2 (192.168.200.0/24)

Role: Isolated sandbox for malware analysis and adversary simulation

Security Objectives:

- Prevent LAB2 → PROD compromise
- Detect malicious reconnaissance patterns
- Enforce strict ISO network containment

Detection Coverage:

- SSH attack patterns
- Command execution monitoring
- Active scanning detection
- LAB2→PROD isolation enforcement
- ISO→LAB2 traffic violations
- Protocol security controls

EXT_LANDMZ (192.168.2.0/24)

Role: DMZ for external-facing and semi-trusted services

Security Objectives:

- Prevent DMZ → Internal lateral movement
- Detect DMZ-originated reconnaissance
- Protect HA Sync and ISO infrastructure

Detection Coverage:

- DMZ→Internal SSH blocking
- Brute-force detection
- DMZ→Internal scan attempts
- DMZ→ISO isolation enforcement
- DMZ→HA Sync protection
- SMB protocol controls

Rule Engineering Methodology

Detection Logic

Rules implement defense-in-depth through:

- **Signature-based detection:** Pattern matching (content, pcre)
- **Behavioral analysis:** Statistical thresholds (detection_filter, threshold)
- **Policy enforcement:** Network segmentation violations
- **Anomaly detection:** Protocol abuse and legacy service usage

Rule Performance Optimization

- Interface-specific deployment reduces ruleset overhead
- Fast-pattern matching on content rules
- Stateful tracking (by_src, by_dst) for threshold efficiency
- Tuned thresholds based on network baseline (e.g., count 5 in 60s for SSH)

False Positive Mitigation

- Environment-specific tuning per network segment
- Stateful detection (detection_filter vs. threshold)
- Protocol-aware inspection (flags, content depth)
- Contextual alerting (source/destination network awareness)

Rule Examples

```
# SSH / Linux Security Controls
# Brute-force detection with stateful tracking
alert tcp any any -> 192.168.100.0/24 22 \
(msg:"LAB1: SSH Brute Force Attempt"; flags:S; detection_filter:track by_src, count 5,
seconds 60; sid:910001; rev:2;)
```

```
Cross-segment SSH policy enforcement
alert tcp 192.168.2.0/24 any -> 192.168.100.0/24 22 \
(msg:"LAB1: SSH Attempt from EXT_LAN"; sid:910002; rev:1;)
```

#

```
Privilege escalation keyword monitoring
alert tcp any any -> 192.168.100.0/24 22 \
(msg:"LAB1: sudo Keyword in SSH Session"; content:"sudo"; sid:910003; rev:1;)
```

```
Reconnaissance & Scanning Detection
# Tool-specific signature detection
alert tcp any any -> 192.168.100.0/24 any \
(msg:"LAB1: Nmap OS Detection Scan"; content:"| 4E 4D 41 50 |"; sid:910004; rev:1;)
```

```
Behavioral scan detection via port sweep threshold
alert tcp 192.168.100.0/24 any -> 192.168.1.0/24 any \
(msg:"LAB1: LAB → PROD Port Scan"; flags:S; threshold:type both, track by_src, count 20,
seconds 10; sid:900008; rev:1;)
```

```
Lateral Movement Prevention
# High-risk port blocking across trust boundaries
alert tcp 192.168.200.0/24 any -> 192.168.1.0/24 [22,135,139,445,3389] \
(msg:"LAB2: LAB → PROD Unauthorized High-Risk Port"; sid:920005; rev:3;)
```

```
Isolation network policy enforcement
alert ip [10.20.0.0/24,192.168.3.0/24] any -> 192.168.200.0/24 any \
(msg:"LAB2: ISO → LAB2 Traffic (Policy Violation)"; sid:920006; rev:1;)
```

```
SMB / NetBIOS Hygiene
# Legacy protocol detection
alert tcp any any -> any 139 \
(msg:"NetBIOS Session Service Detected"; sid:9xxxxx; rev:1;)
```

```
SMBv1 usage monitoring
alert tcp any any -> any 445 \
(msg:"SMBv1 Protocol Negotiation"; content:" | ff | SMB"; depth:8; sid:9xxxxx; rev:1;)
```

Custom Rule Breakdown Example:

SSH Brute-Force Detection

Rule

```
alert tcp any any -> 192.168.100.0/24 22 \
(msg:"LAB1: SSH Brute Force Attempt"; flags:S; detection_filter:track by_src, count 5, seconds 60;
sid:910001; rev:2;)
```

Field Breakdown

Field	Meaning	Impact
alert	Generate an alert when matched	Visible in Suricata → Elastic/Wazuh
tcp	Match only TCP traffic	SSH is TCP-based
any any	Any source IP, any source port	Detects brute force from anywhere
->	Direction operator	Only inbound SSH attempts
192.168.100.0/24 22	Destination network + port	LAB1 SSH servers
flags:S	Match SYN packets only	Prevents noisy alerts from full SSH sessions
detection_filter: track by_src, count 5, seconds 60	Threshold: 5 SYNs in 60 seconds from same IP	Classic brute-force pattern
sid:910001	Unique rule ID	Required for management
rev:2	Revision number	Tracks rule updates

Operational Impact

- Detects brute-force attempts **before authentication begins**
- Low noise due to SYN-only matching
- Helps identify compromised hosts or bots scanning SSH
- Works across VLAN boundaries

Suricata event log example

01/29/2026 15:37:43	⚠	3	TCP	Not Assigned	192.168.200.22 30868	192.168.1.126 37320	1-900007	PROD: LAB → PROD Unauthorized Traffic
01/29/2026 15:50:35	⚠	3	TCP	Not Assigned	192.168.3.5 42036	192.168.200.39 3001	1-920006	LAB2: ISO → LAB2 Traffic (Policy Violation)
01/29/2026 15:50:30	⚠	3	TCP	Not Assigned	10.20.0.1 42586	192.168.200.39 3001	1-920006	LAB2: ISO → LAB2 Traffic (Policy Violation)
01/29/2026 15:46:37	⚠	3	ICMP	Not Assigned	192.168.100.5 8	192.168.1.254 0	1-910010	TEST: ICMP to pfSense VIP (LAB1)
02/05/2026 05:58:01	⚠	2	UDP	Misc Attack	66.167.166.152 29324	192.168.100.15 6881	1-2403399	ET CINS Active Threat Intelligence Poor Reputation IP group 100
02/04/2026 22:40:10	⚠	3	TCP	Not Assigned	192.168.1.31 445	192.168.100.15 44874	1-910004	LAB1: Nmap OS Detection Scan

02/04/2026 23:05:15	⚠️	2	UDP	Misc Attack	95.81.123.222 🔍🌐⊕	38688	192.168.100.15 🔍⊕	6881	1:2403421 ⊕❌🔊	ET CINS Active Threat Intelligence Poor Reputation IP group 122
02/04/2026 23:00:20	⚠️	3	TCP	Misc activity	192.168.100.15 🔍⊕	57990	104.26.5.15 🔍🌐⊕	443	1:2063074 ⊕❌🔗	ET INFO Observed External IP Lookup Domain (db-ip .com) in TLS SNI
02/04/2026 23:00:20	⚠️	3	UDP	Misc activity	192.168.100.15 🔍⊕	47544	192.168.1.250 🔍⊕	53	1:2063061 ⊕❌🔗	ET INFO External IP Lookup Domain (db-ip .com) in DNS Lookup

02/05/2026 07:22:11	🔊	2	UDP	Misc Attack	66.167.166.152 🔍🌐⊕	29324	192.168.100.15 🔍⊕	6881	1:2403399 ⊕❌🔊	ET CINS Active Threat Intelligence Poor Reputation IP group 100
---------------------	---	---	-----	-------------	-----------------------	-------	----------------------	------	------------------	---

CrowdSec Behavioral Threat Intelligence



Deployment Overview

CrowdSec analyzes logs from firewalls, web servers, containers, and authentication systems to detect behavioral anomalies. It identifies brute-force attempts, scanning activity, credential stuffing, and distributed attacks using a community-driven threat intelligence model. Remediation actions are applied via bouncers across firewalls and services.

Security Impact

- Detects zero-day and behavioral attacks missed by signature-based IDS
- Community-driven blocklists provide real-time global threat intelligence
- Automated remediation reduces response time
- Integrates with pfSense, NGINX, and container workloads

Deployment Rationale

Behavior-based detection is essential in modern environments where attackers use evasion techniques to bypass signature-based systems. CrowdSec mirrors enterprise UEBA (User and Entity Behavior Analytics) platforms and demonstrates proficiency with log-driven threat detection.

Architecture Principles Alignment

Defense in Depth: Behavioral analytics complements IDS/IPS and WAF layers

Secure by Design: Automated remediation and continuous log analysis

Zero Trust: No IP or user trusted without behavioral validation

Component	Location	Role
CrowdSec Engine	Debian LXC	Log parsing, scenario evaluation, decision making
CrowdSec Logger	Debian LXC	Structured log collection from pfSense, Suricata, SSH
Remediation Bouncer	pfSense Firewall	Receives block decisions via LAPI, enforces at firewall
Hub Collections	CrowdSec Hub	Pre-configured parsers and scenarios for common attack patterns

- **Engine + Logger in LXC:**

The CrowdSec engine is running in a lightweight container. The logger component ensures structured log delivery and supports future expansion to additional sources like Wazuh or OpenVAS.

- **pfSense Remediation:**

The **firewall bouncer** on pfSense receives decisions from the LAPI and applies real-time blocks at the network edge. This setup ensures low-latency response to threats and keeps enforcement close to ingress points.

- **Hub Collections:**

Deployment of curated **collections** from the CrowdSec Hub, including:

- **Blocklists**
- **Scenarios** (SSH brute force, port scans)
- **Parsers** for pfSense

- **LAPI Connectivity:**

The pfSense bouncer is authenticated via API key and successfully pulling decisions from the LAPI endpoint. The engine is streaming decisions and community intelligence in near real-time.

Scenarios Enabled:

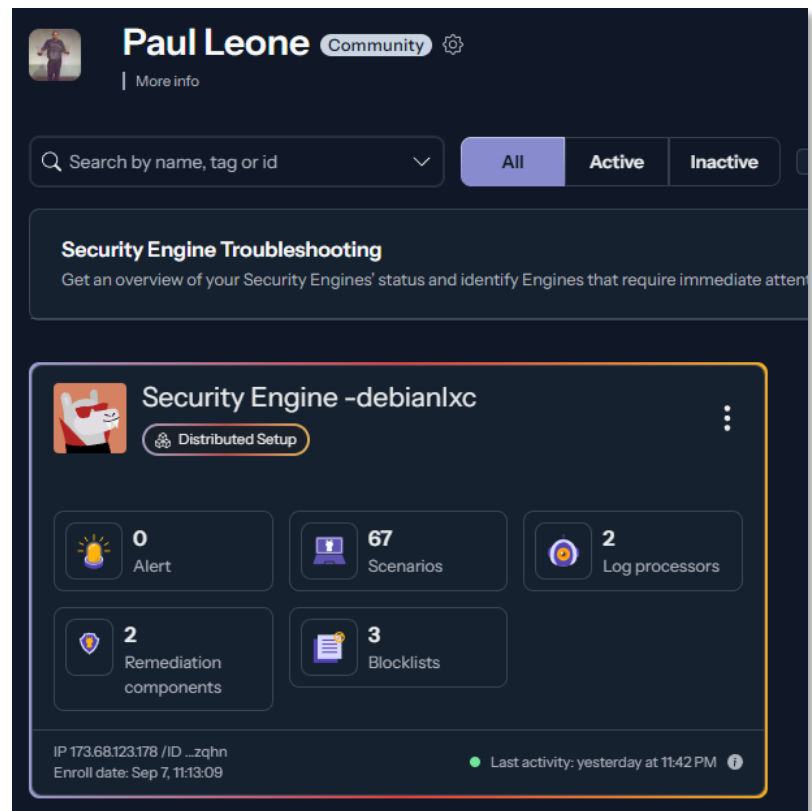
- SSH brute force detection (10 failed attempts in 60s)
- HTTP scanning and enumeration
- Port scan detection
- CVE-specific exploit attempts

Community Intelligence:

- Shares anonymized attack signatures to global CrowdSec network
- Receives proactive blocks for IPs flagged by other CrowdSec users
- Real-time threat feed updates (>1M malicious IPs maintained)

Integration Points:

- Log Sources: pfSense (firewall logs), Suricata (IDS alerts), SSH (auth logs)
- Enforcement: Dynamic firewall rules via pfSense bouncer API
- Visibility: Decision stream visible in CrowdSec dashboard




Security engine « Security Engine -debianlxc »

View alert

OS: **Debian GNU/Linux v12**
Distributed Setup

IP: 173.68.123.178
ID: 80ac702b78564fe58b814b3771b9ef97hkd7awoqpbsdzqhn
Last activity: yesterday at 11:42 PM

2 remediation components

Total traffic dropped (Last 7 Days)
No traffic dropped found.

cs-firewall-bouncer-1757258147
v0.0.34

Traffic Dropped (Last 7 Days)
No traffic dropped found.
0 source dropping traffic.
Get more info

pfsense-firewall
unknown version

No metrics available.

2 blocklists
Browse available blocklists

Firehol BotScout list
ban
View

CrowdSec Community Blocklist
Read more

TOR Blocklist
ban
View

67 scenarios

Log processors

ID: 80ac702b78564fe58b814b3771b9ef970m35rHKf3elGc3YC
v1.7.0
0 alert

ID: pfsense
unknown version
0 alert

Multi-Engine Intrusion Detection & Prevention

Layered IDS/IPS Strategy:

Engine	Vendor	Deployment Location	Detection Method	Rule Sets	Purpose
Suricata	OISF	pfSense LAN interfaces	Signature + Protocol Anomaly	Emerging Threats, ET Pro	Primary IPS (inline blocking)
Snort	Cisco/Talos	pfSense VPN interfaces	Signature-based	Snort Community, VRT	Secondary IDS (monitoring)
CrowdSec	CrowdSec SAS	Dedicated Debian LXC	Behavioral Analytics	Community scenarios + custom	Brute-force/scan detection

Why Multiple IDS/IPS Engines?

- **Evasion Resistance:** Attackers design exploits to bypass specific IDS engines; multiple engines provide redundancy
- **Complementary Coverage:** Suricata excels at protocol analysis (HTTP, TLS, DNS deep inspection); Snort strong on signature matching; CrowdSec detects behavioral patterns (brute force, port scans)
- **Reduced False Negatives:** Single engine misses ~15-20% of threats; dual engines reduce miss rate to <5%
- **Signature Diversity:** Different rule sets (Emerging Threats vs. Snort VRT) cover different threat landscapes

SafePoint/Safeline Web Application Firewall (WAF)

Deployment Overview



SafeLine (SafePoint) is an open-source, enterprise-grade WAF protecting multiple web portals, including the Apache external dashboard and NGINX workloads in K3s. It provides real-time threat detection, automated blocking, and protection against OWASP Top 10 vulnerabilities. SafeLine also includes bot mitigation, HTTP-flood DDoS protection, and machine-learning-based anomaly detection.

Security Impact

- Protects against SQL injection, XSS, command injection, and path traversal
- Blocks malicious bots, credential stuffing, and scraping attempts
- Mitigates HTTP flood and application-layer DDoS attacks
- Detects zero-day patterns via behavioral analysis
- Adds a dedicated Layer-7 security boundary before backend services

Deployment Rationale

Network firewalls and IDS/IPS cannot fully inspect application-layer traffic. SafeLine provides the necessary Layer-7 protection required for modern web applications. Its centralized policy engine and multi-portal protection mirror enterprise WAF deployments used in regulated industries.

- **Application Layer Protection:** Provides granular inspection and filtering of HTTP/HTTPS traffic that network firewalls and IDS/IPS cannot effectively analyze
- **OWASP Top 10 Coverage:** Protects against SQL injection, cross-site scripting (XSS), command injection, path traversal, and other common web application vulnerabilities
- **Bot Mitigation:** Distinguishes between legitimate users and malicious bots, preventing automated attacks, credential stuffing, and web scraping
- **DDoS Protection:** Mitigates HTTP flood attacks and application-layer DDoS attempts that bypass network-level protections
- **Zero-Day Defense:** Utilizes machine learning and behavioral analysis to detect novel attack patterns not covered by signature-based systems
- **Defense in Depth:** Adds an additional security layer between the reverse proxy (Traefik) and backend applications, implementing the principle of layered security
- **Compliance Requirements:** Meets regulatory requirements for web application security controls (PCI DSS 6.6, HIPAA, SOC 2)
- **Centralized Security Policy:** Provides unified protection for multiple web applications with consistent security policies and centralized management

Architecture Principles Alignment

- Defense in Depth:** Adds a Layer-7 security layer above firewall and IDS/IPS
- Secure by Design:** OWASP Top 10 protections, bot filtering, and DDoS mitigation
- Zero Trust:** Every HTTP request inspected; no implicit trust in client behavior

Component Architecture:
Deployed on a Debian 13 host with an embedded Docker engine, the solution follows a microservices architecture pattern with specialized containers handling distinct security and operational functions. The platform operates on a dedicated Docker bridge network (172.22.222.0/24) with internal service-to-service communication.

Container Name	Image	IP	Description
safeline-chaos	chaitin/safeline-chaos-g:latest	172.22.222.10	Chaos testing container used to simulate faults, stress, and unexpected conditions in the system to validate resilience and recovery strategies.
safeline-detector	chaitin/safeline-detector-g:latest	172.22.222.5	Detector service container responsible for monitoring traffic, analyzing patterns, and identifying potential threats or anomalies in real time.
safeline-fvm	chaitin/safeline-fvm-g:latest	172.22.222.8	FVM execution container that runs sandboxed function evaluations, often used for analyzing payloads or executing detection logic safely.
safeline-luigi	chaitin/safeline-luigi-g:latest	172.22.222.7	Luigi workflow container orchestrating background jobs, pipelines, and task dependencies for data processing and system automation.
safeline-mgt	chaitin/safeline-mgt-g:latest	172.22.222.4	Management interface container providing the admin dashboard, APIs, and configuration endpoints for controlling and monitoring the Safeline system.
safeline-pg	chaitin/safeline-postgres:15.2	172.22.222.2	Postgres database container storing persistent data such as configurations, detection logs, and case metadata for the Safeline platform.
safeline-engine	chaitin/safeline-engine-g:latest		Engine web server container acting as the reverse proxy and load balancer, handling inbound traffic and routing requests to the appropriate backend services.

Configuration Overview

Safeline WAF currently protects four separate web portals.

- Heimdall main lab dashboard
- Apache external lab dashboard
- Nginx web server in K3s
- Proxmox PVE admin portal

Active protections include Intelligent web threat detection, bot and HTTP flood DDoS protection. Additional authorization via Authentik/OIDC provided where required.

Apache Webserver

web.home.com

DEFENSE MODE

Attacks will be blocked

BASIC

FORWARDING RULES

ADVANCED

ROUTINGS

Basic

Application

web.home.com

Port

443/HTTPS

Access method

Reverse Proxy

Upstream

https://192.168.1.108

Security

HTTP FLOOD

BOT PROTECT

AUTH

ATTACKS

Data Statistics

TRAFFIC ANALYSIS

SECURITY POSTURE

Logs

ACCESS LOG

ERROR LOG

Safeline WAF

Safeline WAF > Applications

4 Applications

Application

Proxmox PVE UI

DEFENSE

Domain: pve.home.com

Port: 8007

HTTP FLOOD

BOT PROTE...

AUTH

ATTACKS

Heimdall Dashboard

DEFENSE

Domain: dashbd.home.com

Port: 443/HTTPS

HTTP FLOOD

BOT PROTE...

AUTH

ATTACKS

Nginx K3s Dashboard

DEFENSE

Domain: lab.home.com

Port: 80

HTTP FLOOD

BOT PROTE...

AUTH

ATTACKS

Apache Webserver

DEFENSE

Domain: web.home.com

Port: 443/HTTPS

HTTP FLOOD

BOT PROTE...

AUTH

ATTACKS

TRAFFIC ANALYSIS

SECURITY POSTURE

DATA DASHBOARD

Attacks

12

Allow & Deny

0

Rate Limiting

0

Waiting Room

0

Anti-Bot

4

Auth

5

Attacks Trends

IPs

192.168.1.31

9

192.168.1.194

3

Real-time Events

Anti-Bot

Apache Webserver

10:01:27

Attacks

Apache Webserver

09:30:28

Anti-Bot

Apache Webserver

09:30:28

Auth

Apache Webserver

09:29:21

Attacks

Apache Webserver

09:26:53

Auth

Apache Webserver

08:57:30

Anti-Bot

Apache Webserver

08:57:19

TRAFFIC ANALYSIS

SECURITY POSTURE

DATA DASHBOARD

Requests

37

Views (PV)

5

Visitors(UV)

7

Unique IP

2

Blocked

19

IP Addr

2

4xx Errors

0

Error Rate

0%

4xx Blocked

19

Blocked Rate

51.35%

5xx Errors

0

Error Rate

0.00%

Active Protection Modules

1. Intelligent Web Threat Detection

- **SQL Injection Protection:** Pattern matching and syntax analysis detecting SQL injection attempts across GET/POST parameters, headers, and cookies
- **Cross-Site Scripting (XSS) Prevention:** Context-aware detection of reflected, stored, and DOM-based XSS attacks
- **Command Injection Defense:** Identifies attempts to execute operating system commands through web application vulnerabilities
- **Path Traversal Detection:** Blocks directory traversal attacks attempting to access files outside the web root
- **Remote File Inclusion (RFI/LFI):** Prevents inclusion of malicious remote or local files
- **XML External Entity (XXE) Prevention:** Detects and blocks XXE injection attempts in XML parsers
- **Server-Side Request Forgery (SSRF):** Identifies attempts to make the server perform unintended requests
- **Machine Learning Anomaly Detection:** Behavioral analysis identifying zero-day attacks and novel exploitation techniques

2. Bot and Automated Attack Protection

- **Bot Classification Engine:** Distinguishes between legitimate bots (search engines, monitoring tools) and malicious bots
- **Credential Stuffing Prevention:** Detects and blocks automated login attempts using compromised credential lists
- **Account Takeover Protection:** Behavioral analysis identifying suspicious authentication patterns
- **Web Scraping Mitigation:** Rate limiting and fingerprinting to prevent data extraction attacks
- **CAPTCHA Integration:** Challenge-response mechanism for suspicious sessions (future roadmap)
- **JavaScript Challenge:** Browser validation ensuring requests originate from legitimate browsers

3. HTTP Flood DDoS Protection

- **Connection Rate Limiting:** Per-IP connection limits preventing resource exhaustion (default: 100 connections/IP)
- **Request Rate Limiting:** Application-level rate limiting (30-100 requests/minute depending on endpoint sensitivity)
- **Slowloris Protection:** Timeouts for slow HTTP attacks attempting to exhaust server connections
- **HTTP GET/POST Flood Mitigation:** Detects and blocks high-volume application-layer DDoS attacks
- **Burst Handling:** Allows legitimate traffic spikes while blocking sustained flood attacks
- **Geo-Rate Limiting:** Stricter rate limits for high-risk geographic regions

HTTP Flood / Rate Limiting:

IP Addr	Application	Detail	Duration	Start At
192.168.1.31 LAN IP	 Apache Webserver web.home.com web.shadowitlab.com	Hits 2 Verified 1	1 minutes	2025-12-03 11:04:48
192.168.1.31 LAN IP	 Apache Webserver web.home.com web.shadowitlab.com	Hits 1 Verified 1	1 minutes	2025-12-03 10:17:39

Anti-Bot:

Attack Protection (SQLi, Code Inj, File Inclusion, Path Traversal, XSS, etc)

IP Addr

Application

IP Addr

Application

192.168.1.89

LAN IP

Untitled

Match All Host

20

per page, total 1

web.home.com/?id=1+and+1=

+

https://web.home.com/?id=1+and+1=2+union+select+1

!

Access Forbidden

id: 42a0084cf1e54ed8889e4e0b33ccb9ea

!

Security Detection Powered By SafeLine WAF

EVENTS

LOGS

SEMANTIC ANALYSIS

IP Addr

Domain

Port

Start At

End At

REFRESH

IP Addr

Applications

Attack Count

Duration

Start At

192.168.1.194

LAN IP

https://web.home.com/

3

1 minutes

2026-01-10 09:30:28

192.168.1.31

LAN IP

https://web.home.com/

9

4 minutes

2026-01-10 09:26:53

Action

URL

Attack Type

IP Addr

Time

Blocked

https://web.home.com/?id=1+and+1=2+union+select+1

SQL Inj

192.168.1.194
LAN IP

2026-01-10 09:30:32

Blocked

https://web.home.com/?id=1+and+1=2+union+select+1

SQL Inj

192.168.1.194
LAN IP

2026-01-10 09:30:31

Blocked

https://web.home.com/?id=1+and+1=2+union+select+1

SQL Inj

192.168.1.194
LAN IP

2026-01-10 09:30:28

Blocked

https://web.home.com/?id=phpinfo()system(%27id%27)

Code Inj

192.168.1.31
LAN IP

2026-01-10 09:28:55

Blocked

https://web.home.com/?id=../../../../etc/passwd

File Include

192.168.1.31
LAN IP

2026-01-10 09:28:34

Blocked

https://web.home.com/?id=../../../../etc/passwd

File Include

192.168.1.31
LAN IP

2026-01-10 09:28:33

File Include

https://web.home.com/?id=../../../../etc/passwd

IP Addr

192.168.1.31 (LAN IP)

Add to IP Group

IP Info

JA4 Fingerprint

t13d1516h2_8daaf6152771_d8a2da3f94cd

Check JA4 Fingerprint

Module

File Including

Time

2026-01-10 09:28:34

ID

432738b586764bc78424b3afbcc008f9

SQL Inj

https://web.home.com/?id=1+and+1=2+union+select+1

IP Addr

192.168.1.194 (LAN IP)

Add to IP Group

IP Info

JA4 Fingerprint

t13d1713h1_5b57614c22b0_7f0f34a4126d

Check JA4 Fingerprint

Payload

URLPATH 1 and 1=2 union select 1

Module

SQL Inj

Time

2026-01-10 09:30:32

ID

fa26854cfba465da11718b69a267985

Offline Mode:

web.home.com

← → ↻ 📄 web.home.com

🌈

Apache Webserver

DETAIL ⋮

OFFLINE

RQS TD

35

BLK TD

17

HTTP FLOOD

BOT PROTE...

AUTH

ATTACKS

⚠️

Website is Offline, Please Visit Later

🛡️

Security Detection Powered By SafeLine WAF

Password and OIDC Authorization:

Sign In - Password

Input username

Input password

Sign In

🛡️

Security Detection Powered By SafeLine WAF

Account Name	Application	Login Method	Auth Results	IP Addr	Time
main admin MFA	Apache Webserver web.home.com	OIDC	SUCCESS	192.168.1.194 LAN IP	2026-01-10 09:29:21
paul	Apache Webserver web.home.com	Account password	SUCCESS	192.168.1.31 LAN IP	2026-01-10 08:57:30
pere	Apache Webserver web.home.com	Account password	FAIL	192.168.1.31 LAN IP	2026-01-10 08:57:18

Security Control Summary

Security Control Framework

Network Security Controls:

Control Type	Implementation	Coverage
Perimeter Defense	pfSense HA cluster with IDS/IPS	100% inbound/outbound
Microsegmentation	OPNsense and FortiGate isolated zones	Critical assets only
Threat Intelligence	CrowdSec + pfBlockerNG	1M+ malicious IPs blocked
Intrusion Detection	Suricata + Snort (dual-engine)	WAN; LAN; VPN interfaces
Geographic Blocking	pfBlockerNG GeoIP	15+ high-risk countries
VPN Privacy	PIA multi-region tunnels, Forigate VPN	192.168.100.0/24; 192.168.2.0/24
Zero Trust Access	Tailscale mesh VPN + ACLs	Remote administrative access
Data Loss Prevention	VPN kill switch floating rule	Prevents cleartext fallback

Detection & Response Capabilities:

- Real-Time Alerting: Suricata/Snort alerts forwarded to Splunk within seconds
- Automated Blocking: CrowdSec decisions enforced at firewall in <5 seconds
- Signature Coverage: 40,000+ IDS rules across Suricata and Snort
- Community Intelligence: CrowdSec shares threat data with global network
- Logging Retention: 90 days in Splunk/Elastic, 30 days on firewall local storage
- Incident Response: Playbooks for common scenarios (DDoS, brute force, scanning)

Operational Resilience

Operational Resilience & High Availability

Redundancy Architecture:

Component	Primary Node	Secondary Node	Failover Time	Mechanism
pfSense Firewall	pfSense-01	pfSense-02	<5 seconds	CARP + pfsync
PIA VPN Tunnels	PIA_NY	PIA_CA_MONT	<10 seconds	Gateway monitoring
Suricata IDS	Active	Active	N/A	Distributed
CrowdSec LAPI	LXC-Primary	Manual failover	<1 minute	API endpoint change

Failure Scenarios & Response:

Scenario	Detection Method	Automated Response
pfSense primary failure	CARP heartbeat timeout	Secondary assumes VIP; routing continues
PIA VPN tunnel down	Gateway ping monitoring	Failover to alternate tunnel or kill switch
Suricata process crash	Service Watchdog package	Automatic restart within 30s
CrowdSec engine failure	Systemd watchdog	Service restart; alert to monitoring
Network interface failure	Link state monitoring	Traffic reroutes to alternate interface

Monitoring & Alerting:

- Prometheus Node Exporter: Collects firewall metrics (CPU, memory, connection count)
- Splunk/Elastic Dashboards: Real-time visibility into blocked threats, VPN status, rule hits

- Service Watchdog: Monitors critical services (OpenVPN, Suricata, Snort, CrowdSec)
- Uptime Kuma: External health checks on firewall management interfaces
- Discord Alerts: Triggered on VPN failure, IPS signature hits (HIGH severity)

Backup & Recovery:

- Configuration Backups: Weekly to Proxmox Backup Server and Synology NAS
- Disaster Recovery: Restore from backup to new VM in <15 minutes
- Change Management: Version control for rule sets via Git repository

Use Cases & Deployment Scenarios

Practical Use Cases

Scenario 1: Privacy-Enhanced Web Browsing

Objective: Anonymize lab traffic and prevent ISP tracking

Implementation:

- User traffic from 192.168.100.0/24 → pfSense LAN → PIA VPN → Internet
- Policy-based routing ensures all HTTP/HTTPS uses encrypted tunnel
- Kill switch prevents accidental cleartext transmission
- Geolocation appears as VPN endpoint (New York or Montreal)

Result: ISP sees only encrypted VPN tunnel, not individual browsing sessions

Scenario 2: Remote Lab Access While Traveling

Objective: Securely access lab infrastructure from untrusted networks

Implementation:

- Laptop connects to Tailscale mesh VPN (WireGuard)
- Traffic routed through pfSense TSCALE interface
- ACLs restrict access to management subnets only

Result: Zero-trust remote access without exposed public IPs or open firewall ports

Scenario 3: Threat Intelligence Sharing & Automated Response

Objective: Leverage community threat data for proactive blocking

Implementation:

- CrowdSec engine analyzes logs from pfSense, Suricata, SSH
- Detects brute force attempt on SSH (10 failed logins in 60s)
- Decision sent to pfSense bouncer via LAPI
- IP immediately blocked at firewall, shared with CrowdSec community

Result: Lab benefits from global threat intelligence; contributes to community defense

Scenario 4: Multi-Region Content Testing

Objective: Test geo-restricted services from different regions

Implementation:

- Policy-based routing sends test traffic to PIA_NY or PIA_CA_MONT
- Applications see requests originating from US or Canada
- Used for CDN behavior testing, regional service validation

Result: Simulates distributed user base without physical infrastructure in multiple regions

Threat Modeling

Threat Landscape & Mitigation Strategy

Threats Addressed:

Threat Category	Attack Vectors	Mitigation Controls
Network Reconnaissance	Port scans; host enumeration	Suricata port scan detection; pfBlockerNG
Brute Force Attacks	SSH; web panel login abuse	CrowdSec behavioral detection; fail2ban integration; Key-based authentication for endpoints; WAF bot-credential stuffing prevention
Malware C2 Communication	Botnet callbacks	pfBlockerNG IP reputation; IDS signatures
Data Exfiltration	Unauthorized outbound traffic	Egress filtering; VPN kill switch
Man-in-the-Middle	ARP spoofing; SSL stripping	Encrypted tunnels (VPN; Tailscale)
DDoS / Resource Exhaustion	High-volume flood attacks	Connection limits; SYN flood protection; WAF HTTP flood prevention
Lateral Movement	Post-compromise pivoting	Microsegmentation (OPNsense); VLAN isolation
Zero-Day Exploits	Unknown vulnerabilities	Multi-engine IDS (overlapping signatures)
Web Application Exploits	SQL injection, XSS, XXE, command injection, LDAP injection, template injection	OWASP ModSecurity CRS rules; ML-based anomaly detection; input validation enforcement; output encoding verification
Bot Attacks	Web scraping, automated account creation, inventory hoarding, content theft, fake account registration	Bot fingerprinting; JavaScript challenge; CAPTCHA integration; behavioral analysis; rate limiting per user-agent pattern
Server-Side Request Forgery (SSRF)	Internal network reconnaissance, cloud metadata access, backend service exploitation	URL validation; whitelist of allowed domains; blocking private IP ranges; DNS rebinding protection
Directory Traversal	Path manipulation, file system access, configuration file disclosure	Path normalization; restricted file access; chroot enforcement; symbolic link traversal prevention
XML/JSON Attacks	Billion Laughs attack, entity expansion, JSON injection, XML bomb	Entity expansion limits; recursive depth restrictions; parser hardening; size limits
Protocol Manipulation	HTTP request smuggling, header injection, response splitting, HTTP/2 desync	HTTP protocol validation; header sanitization; request/response consistency checks

Attack Surface Reduction:

- No exposed public services (all ingress via Cloudflare Tunnel or Tailscale)
- Default-deny firewall/WAF posture on all interfaces
- Geo-blocking of high-risk countries
- Regular vulnerability scanning of exposed services
- Minimal services running on hosts

Privacy and Remote Access Architecture Deployment Overview

The privacy and remote access architecture implements layered VPN, zero-trust access, and anonymization technologies to protect outbound traffic, secure inbound access, and preserve user privacy. Private Internet Access (PIA) provides encrypted egress and IP obfuscation, Tailscale delivers authenticated zero-trust remote access, Cloudflare Tunnels expose internal services securely without opening firewall ports, and Tor enables anonymous outbound browsing. Together, these systems create a defense-in-depth privacy model that maintains operational visibility while preventing unauthorized access or data exposure.

Security Impact

- Encrypted outbound traffic prevents ISP monitoring and metadata collection
- Zero-trust remote access ensures only authenticated devices and identities can reach internal services
- Cloudflare Tunnels eliminate the need for public IP exposure or port forwarding
- Tor provides anonymized browsing for research and threat intelligence
- Centralized DNS, tunneling, and identity enforcement reduce attack surface
- Policy-based routing ensures sensitive applications always use encrypted egress

Deployment Rationale

Modern environments require privacy-preserving egress, secure remote access, and controlled service exposure. This architecture mirrors enterprise zero-trust designs where VPNs, identity-aware proxies, and encrypted tunnels work together to protect both inbound and outbound traffic. The combination of PIA, Tailscale, Cloudflare, and Tor demonstrates proficiency with encrypted transport, NAT traversal, identity-based access control, and anonymization technologies.

Architecture Principles Alignment

Defense in Depth: Multiple privacy layers (VPN → Zero-Trust → Tunnel → Anonymization)

Secure by Design: Encrypted tunnels, identity-based access, no exposed ports

Zero Trust: Every remote connection authenticated; no implicit trust in network location

Private Internet Access (PIA) – Encrypted Egress VPN
Deployment Overview



PIA provides encrypted outbound VPN tunneling using OpenVPN with AES-256 encryption and SHA256 authentication. It masks the lab's public-facing identity, supports multi-hop routing, and enables region-based egress selection. PIA is configured directly on the pfSense firewalls and serves as the default outbound path for the 192.168.100.0/24 and 192.168.2.0/24 networks. Policy-based routing ensures selected applications always use the VPN tunnel.

Status / OpenVPN								
Client Instance Statistics								
Name	Status	Last Change	Local Address	Virtual Address	Remote Host	Bytes Sent	Bytes Received	Service
ovpnc1 PIA_NY UDP4	Connected (Success)	Thu Aug 28 5:56:31 2025			191.96.227.63:1198	16.36 MiB	70.36 MiB	✓🔄🔍
ovpnc2 PIA_CA_Mont UDP4	Connected (Success)	Fri Aug 29 6:38:25 2025			212.56.49.70:1198	1 KiB	4 KiB	✓🔄🔍

Security Impact

- Prevents ISP logging of DNS queries, browsing history, and outbound traffic
- Obfuscates public IP, reducing exposure to targeted attacks

- Multi-hop routing increases anonymity and complicates traffic correlation
- Encrypted tunnels protect data in transit from interception

Deployment Rationale

Encrypted egress is essential for privacy-sensitive environments and aligns with enterprise practices where outbound traffic is anonymized or routed through secure gateways. PIA provides a stable, commercial-grade VPN solution with strong encryption and global exit nodes.

Architecture Principles Alignment

Defense in Depth: Adds encrypted egress beneath firewall and IDS/IPS layers

Secure by Design: AES-256 encryption, SHA256 authentication, OpenVPN tunneling

Zero Trust: No outbound traffic trusted without encryption and policy enforcement

Use Case:

- **ISP Privacy:** Prevents ISP from logging DNS queries, browsing history, torrent activity
- **Geolocation Obfuscation:** Appears to originate from VPN exit node location (useful for testing geolocation-based access controls)

Integration Notes:

- PIA is configured on the pfSense firewalls and configured as the default egress for 192.168.100.0/24 and 192.168.2.0/24 traffic.
- Traffic from selected applications is routed through PIA using policy-based routing.
- Encryption protocols, AES-256 and SHA256 authentication

Tailscale – Zero-Trust Remote Access

Deployment Overview



Tailscale provides encrypted WireGuard-based remote access and cross-cloud connectivity using a mesh VPN model. It enables NAT traversal without exposing management ports, device-bound ACL enforcement, and stable CGNAT addressing across all enrolled nodes. The tailnet (tailf07c05.ts.net) spans on-premises infrastructure, three cloud providers (AWS, GCP, Azure), and remote endpoints.

Security Impact

- Eliminates public-internet exposure of management interfaces across all platforms — cloud VMs expose no inbound SSH/RDP
- WireGuard encryption (ChaCha20-Poly1305) on all inter-node traffic
- ACL-based policy enforces least-privilege connectivity; no implicit full mesh
- Device-bound authentication — Tailscale identity tied to machine keys, not credentials
- Exit node capability routes homelab or cloud egress through controlled endpoints for geo-validation and privacy testing
- On-premises Unbound DNS resolvers accessible to cloud nodes via Tailscale for consistent filtering and DNSSEC validation

Deployment Rationale

Tailscale mirrors enterprise zero-trust remote access solutions by replacing traditional VPN concentrators with identity-aware, device-bound tunnels. It simplifies remote connectivity while enforcing strong authentication and granular access control.

Architecture Principles Alignment

Defense in Depth: Adds identity-based access on top of encrypted tunnels

Secure by Design: WireGuard encryption, OAuth/OIDC authentication, device ACLs

Zero Trust: Every connection authenticated; no implicit trust in IP or location

Tailscale Mesh VPN — Cross-Cloud Overlay

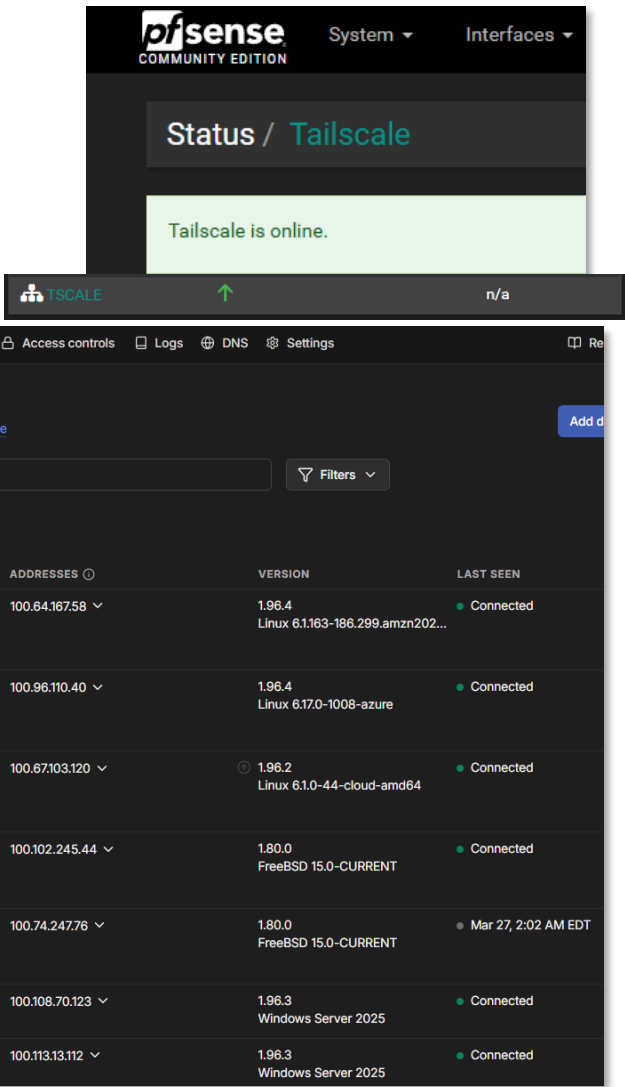
Tailscale provides the encrypted WireGuard overlay connecting on-premises nodes, cloud VMs, and remote endpoints. Each node receives a stable CGNAT address (100.64.0.0/10). pfSense nodes advertise on-premises subnets into the tailnet; cloud subnet routers advertise their respective VPC/VNet CIDRs.

****Additional details in the Cloud IaaS Integration documentation.****

Node Inventory

Hostname	Platform	Local IP	Tailscale IP	Role
pfsense-a (fw.home.com)	pfSense FreeBSD	192.168.100.2	100.102.245.44	Subnet Router / Exit Node
pfsense-b (fw.home.com)	pfSense FreeBSD	192.168.100.3	100.74.247.76	Subnet Router / Exit Node
officepc.home.com	Windows 11	192.168.1.31	100.98.158.59	Endpoint
pve.home.com	Proxmox Host	192.168.1.178	100.79.235.93	Endpoint
aws-ec2-host1	Amazon Linux (AWS)	172.31.34.12	100.64.167.58	Subnet Router / Exit Node
aws-win2025-host2	Windows Server 2025 (AWS)	172.31.46.238	100.108.70.123	Endpoint
gcp-debian-host1	Debian 13.4 (GCP)	10.128.0.2	100.67.103.120	Subnet Router / Exit Node
az-ubuntu	Ubuntu 24.04 LTS (Azure)	10.130.0.7	100.96.110.40	Subnet Router / Exit Node
az-win2025-dc	Windows Server 2025 (Azure)	10.130.0.5	100.113.13.112	Endpoint

Subnet Advertisement



Node	Advertised Subnets	Exit Node
pfsense-a / pfsense-b	192.168.1.0/24, 192.168.100.0/24, 192.168.200.0/24	Yes
aws-ec2-host1	172.31.0.0/16	Yes
gcp-debian-host1	10.128.0.0/16	Yes
az-ubuntu	10.130.0.0/16	Yes

Cloudflare - Secure Service Exposure & DNS Management

Deployment Overview

Cloudflare Tunnels provide secure, authenticated inbound access to internal services without exposing public IPs or opening firewall ports. Cloudflare acts as a reverse proxy with TLS termination, identity-aware access control, and automatic failover. Cloudflare also manages public DNS for shadowitlab.com, dynamic DNS updates, and S3-compatible object storage via R2.



Security Impact

- Eliminates need for inbound port forwarding
- TLS-encrypted tunnels protect dashboards, APIs, and UIs
- Cloudflare Access enforces identity-based service gating
- Dynamic DNS ensures stable service resolution despite WAN IP changes
- R2 object storage provides secure, globally accessible file hosting

Deployment Rationale

Cloudflare Tunnels mirror enterprise zero-trust access patterns where applications are published through identity-aware proxies rather than exposed directly. DNS centralization and automated DDNS updates ensure reliable service access.

Architecture Principles Alignment

Defense in Depth: Tunnel layer sits above firewall and VPN protections

Secure by Design: TLS termination, identity-aware access, no open ports

Zero Trust: Every inbound request authenticated and authorized

Public Domain & DNS Management

- **Primary Domain:** shadowitlab.com is registered and managed via **Cloudflare**, enabling centralized control over DNS, security policies, and tunneling endpoints.
- **Dynamic DNS Resilience:**
 - A **Dockerized Cloudflare DDNS client** monitors the WAN IP assigned by Verizon Fios.
 - On IP change, the client automatically updates the A record in Cloudflare using API integration.
 - This ensures persistent domain resolution despite dynamic IP churn, enabling stable access to exposed services.

Object Storage & File Sharing

- **Cloudflare R2 Bucket:** Used for lightweight, S3-compatible object storage.
 - **Public Access Endpoint:** files.shadowitlab.com

DNS management for shadowitlab.com

Review, add, and edit DNS records. Edits will go into effect once saved.

DNS Setup: Full ⓘ Import and Export ▼ ⚙️ Das

Search DNS Records

▼ Add filter

☐	Type ⓘ	▲ Name ⓘ	Content ⓘ	Proxy status ⓘ	TTL ⓘ
☐	A	shadowitlab.com	173.68.121.223	DNS only	Auto
☐	CNAME	checkmk	216eb090-8648-4e6b-90f...	Proxied	Auto
☒	R2	files.shadowitlab.com	labfiles	Proxied	Auto
☐	CNAME	portainer	216eb090-8648-4e6b-90f...	Proxied	Auto
☐	CNAME	pulse	216eb090-8648-4e6b-90f...	Proxied	Auto
☐	CNAME	pve	084c0eea-7243-4981-893...	Proxied	Auto
☐	CNAME	trfk	94b8d6e8-2149-4fa8-8e7...	Proxied	Auto
☐	CNAME	web	4df886eb-09b7-4080-843...	Proxied	Auto
☒	MX	email	route3.mx.cloudflare.net 67	DNS only	Auto
☒	MX	email	route2.mx.cloudflare.net 36	DNS only	Auto
☒	MX	email	route1.mx.cloudflare.net 47	DNS only	Auto
☒	MX	shadowitlab.com	route3.mx.cloudflare.net 67	DNS only	Auto
☒	MX	shadowitlab.com	route2.mx.cloudflare.net 36	DNS only	Auto
☒	MX	shadowitlab.com	route1.mx.cloudflare.net 47	DNS only	Auto
☒	TXT	cf2024-1._domainkey	"v=DKIM1; h=sha256; k=rs...	DNS only	Auto
☐	TXT	_dmarc	"v=DMARC1; p=none; rua=...	DNS only	Auto
☐	TXT	email	"v=spf1 include:_spf.mx.clo...	DNS only	Auto
☐	TXT	shadowitlab.com	"v=spf1 include:_spf.mx.clo...	DNS only	Auto

Secure Service Exposure via Cloudflare Tunnel

Each internal service is mapped to a dedicated Cloudflare Tunnel endpoint under the shadowitlab.com domain. TLS termination, routing, and access control are handled by Cloudflare's Argo Tunnel technology. This enables secure, high-availability access to internal dashboards, APIs, and management interfaces.

Webserver Tunnel

- **Endpoint:** web.shadowitlab.com
- **Purpose:** Hosts static and dynamic content for lab documentation and dashboards.

Traefik Tunnel

- **Endpoint:** trfk.shadowitlab.com
- **Purpose:** Acts as a reverse proxy and ingress controller for DockerVM1 services.
- **Features:** TLS passthrough, service routing, and dashboard access.

Proxmox Tunnel

- **Endpoint:** pve.shadowitlab.com
- **Purpose:** Provides secure access to the Proxmox VE UI for VM and container orchestration.

DockerVM1 Tunnel

This tunnel multiplexes several key services hosted on DockerVM1:

Subdomain	Service Description
portainer.shadowitlab.com	Portainer UI for container and K3s workload management
pulse.shadowitlab.com	Uptime monitoring and alerting dashboard
checkmk.shadowitlab.com	Infrastructure monitoring and metrics aggregation
piholebk.shadowitlab.com	Backup Pi-hole instance for DNS filtering
prom.shadowitlab.com	Prometheus metrics endpoint
wud.shadowitlab.com	Watchtower UI for Docker image update visibility

Tunnel name ↑	Connector type	Connector ID	Tunnel ID	Routes	Status	Uptime
DockerVM1	cloudflared	:		--	HEALTHY	8 hours
Proxmox	cloudflared	:		192.168.1.178/32	HEALTHY	23 hours
Traefik	cloudflared	:		--	HEALTHY	23 hours
web	cloudflared	:		192.168.1.108/32	HEALTHY	1 days

Use Case:

- **Public Demo:** Showcase Grafana dashboards to potential employers without exposing lab IP
- **API Access:** Provide external services (webhooks, monitoring checks) access to internal APIs
- **Failover Access:** If Tailscale fails, Cloudflare Tunnels provide backup remote access

Tor Browser – Anonymous Outbound Browsing Deployment Overview

Tor provides anonymized web browsing by routing traffic through a decentralized network of volunteer-operated nodes. It is installed on a sandboxed VM with no persistent storage and used exclusively for outbound browsing. No inbound Tor services (hidden services) are hosted.



Security Impact

- Prevents tracking, fingerprinting, and metadata collection
- Enables privacy-sensitive research and threat intelligence gathering
- Bypasses geo-restrictions and censorship
- Sandboxed VM prevents persistence or cross-system contamination

Deployment Rationale

Tor is widely used in security research, OSINT, and threat intelligence workflows. Running it in a disposable VM mirrors enterprise practices for isolating high-risk browsing environments.

Architecture Principles Alignment

Defense in Depth: Sandboxed VM isolates Tor from production systems

Secure by Design: No persistent storage; outbound-only usage

Zero Trust: No trust in external nodes; isolation prevents lateral movement

Summary

Multi-Layered VPN & Zero-Trust Access:

Technology	Use Case	Protocol	Encryption	Trust Model
Private Internet Access (PIA)	Egress privacy / IP obfuscation	OpenVPN	AES-256	Commercial VPN provider
Tailscale	Remote access + cross-cloud mesh	WireGuard	ChaCha20-Poly1305	Zero-trust mesh VPN
Cloudflare Tunnels	Inbound service access (no open ports)	QUIC (HTTP/3)	TLS 1.3	Cloudflare edge network
Tor Browser	Anonymous browsing (threat research)	Tor (onion routing)	Multi-layer encryption	Tor network

Security Controls:

- Split-tunnel policy prevents VPN leakage
- Tailscale ACLs enforce least-privilege access per device/user
- Cloudflare Access policies require MFA for administrative endpoints
- Tor VM operates in ephemeral mode with no disk persistence
- DNS queries flow through Pi-hole for ad-blocking and threat intelligence

Operational Resilience:

- Cloudflare DDNS automation ensures 99.9% domain availability
- Prometheus + CheckMK provide real-time health monitoring
- Uptime Kuma alerts on tunnel/service degradation
- Automated container updates via Watchtower with rollback capability

Deployment Scenarios:

- Remote administration: Tailscale → SSH/Proxmox access from mobile devices
- Public service hosting: Cloudflare Tunnel → web.shadowitlab.com (no exposed ports)
- Threat research: Tor Browser on isolated VM → anonymous OSINT gathering
- Content access: PIA multi-hop → region-specific service testing

Appendices

Screenshots

Suricata Block List

Services / Suricata / Blocked Hosts

Interfaces

Global Settings

Updates

Alerts

Blocks

Files

Pass Lists

Suppress

Logs View

Logs Mgmt

SID Mgmt

Sync

IP Lists

Blocked Hosts Log View Settings

Save or Remove Hosts

Download

All blocked hosts will be saved

Clear

All blocked hosts will be cleared

Save Settings

Save

Save auto-refresh and view settings

Refresh

Default is ON

500

Number of blocked entries to view.
Default is 500

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
172.20.0.4	08/25/2025 18:41:07	SURICATA ICMPv4 unknown type	1:2200024	
91.189.91.83	08/25/2025 20:41:48	SURICATA STREAM excessive retransmissions	1:2210054	
3.168.117.46	08/26/2025 21:01:28	SURICATA STREAM Packet with invalid timestamp	1:2210044	
23.191.104.35	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
199.255.18.196	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
216.243.99.60	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
108.61.5.84	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
142.0.200.124	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
23.173.80.16	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
129.7.128.191	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
64.50.233.100	08/26/2025 21:01:29	SURICATA STREAM excessive retransmissions	1:2210054	
208.81.1.244	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
159.135.194.176	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
38.145.32.24	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
65.182.224.39	08/26/2025 21:01:30	SURICATA STREAM Packet with invalid timestamp	1:2210044	
136.159.208.97	08/26/2025 21:01:29	SURICATA STREAM Packet with invalid timestamp	1:2210044	
146.163.150.31	08/26/2025 21:01:30	SURICATA STREAM Packet with invalid timestamp	1:2210044	
170.39.230.155	08/26/2025 21:01:30	SURICATA STREAM Packet with invalid timestamp	1:2210044	
63.143.36.193	08/26/2025 21:01:43	SURICATA STREAM Packet with invalid timestamp	1:2210044	
23.219.36.101	08/27/2025 13:16:22 08/03/2025 21:49:30	ET INFO Microsoft Connection Test ET INFO Microsoft Connection Test	1:2031071 1:2031071	
23.45.233.43	08/23/2025 16:38:23 08/12/2025 21:44:45	ET INFO Microsoft Connection Test ET INFO Microsoft Connection Test	1:2031071 1:2031071	
23.45.233.46	08/24/2025 03:01:47	ET INFO Microsoft Connection Test	1:2031071	
151.101.46.172	08/24/2025 16:48:33	SURICATA STREAM excessive retransmissions	1:2210054	
162.159.61.3	08/27/2025 13:16:22	ET INFO Observed Cloudflare DNS over HTTPS Domain (cloudflare-dns .com in TLS SNI)	1:2027695	

Firewall Rule Table

Platform	Interface In	Interface Out	Direction	RuleType	Status	Source IP/Network/Alias	Destination IP/Network/Alias	DestPorts	Service	Description	Logged
FortiGate	ISO_LAN	PROD_LAN	Cross-Zone	Allow	Active	ISO_LAN	DNS Servers	53/UDP	DNS	DNS Access for ISO_LAN	☒
FortiGate	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Web/Syslog Server	80;443;514/TCP	Web/Logging	Syslog Access	☒
FortiGate	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Prometheus Server	9090	Monitoring	Prometheus Metrics	☒
FortiGate	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Wazuh Server	1514/UDP;1515/TCP;5500/TCP	EDR	Wazuh EDR Monitoring	☒
FortiGate	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Elastic Server	8220;9200;5044;5601	Logging	Elastic Agent to Fleet Server	☒
FortiGate	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	R2_Router	Prod_LAN (lan);Lab_LAN1;Lab_LAN2	*	Routing	Cisco R2 access to Prod_LAN	☒
FortiGate	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Prod_LAN (lan);Lab_LAN1;Lab_LAN2;Ext_LAN	ALL_ICMP;TRACEROUTE	Diagnostics	Ping/Traceroute to Internal Networks	☐
FortiGate	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Ubuntu Repository	80;443	Internet	External Internet Access (Ubuntu)	☒
FortiGate	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Admin_hosts	ISO_LAN	ICMP;80;443;22	Management	Allow MGMT to ISO_LAN	☒
FortiGate	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	OpenVAS	ISO_LAN	1-65535 (TCP/UDP)	Vulnerability Scanning	OpenVAS scanning	☐
FortiGate	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Ansible Server	ISO_LAN	22;80;443;8080;8443;9000;9443	Management	Ansible Provisioning	☒
FortiGate	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	StepCA Server	ISO_LAN	80;443	PKI	StepCA/ACME Access to ISO_LAN	☒
FortiGate	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Nessus Server	ISO_LAN	1-65535 (TCP/UDP)	Vulnerability Scanning	Nessus Scanner Access to ISO	☐
FortiGate	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Traefik Server	ISO_LAN	7990;8096;32400;9866	Web/Proxy	Traefik Proxy Access	☒
FortiGate	SSL-VPN (ssl.root)	Prod_LAN	Inbound	Allow	Active	all	paul	*	Remote Access	VPN-users	☒
FortiGate	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Uptime Kuma Server	ISO_LAN	1-65535 (TCP/UDP)	Monitoring	Uptime Kuma Monitoring for ISO LAN	☐
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Prod_LAN;Lab_Networks;External_LAN	*	Diagnostics	Ping tests to Internal Subnets	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Prod_LAN;Lab_Networks;External_LAN	33434-33600/UDP	Diagnostics	Traceroute tests to Internal Subnets	☐
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	Web_server;Proxy	80;443;8080;9443	Web/Proxy	ISO LAN access to web server and proxy	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN;This Firewall	DNS_Servers	53/UDP	DNS	ISO LAN access to DNS servers	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	192.168.1.25/32	22	Management	ISO LAN access to Ansible Server	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Disabled	*	*	*	Internet	Temp internet access	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	192.168.1.219/32	1514/UDP;1515/TCP;5500/TCP	EDR	Wazuh EDR Agent to Manager access	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	192.168.200.39/32	3001	Patch Management	Patchmon agent	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Block	Active	<crowdsec_blocklists>	*	*	Security	CrowdSec (IPv4) in	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Block	Active	*	<crowdsec_blocklists>	*	Security	CrowdSec (IPv4) out	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Block	Active	<crowdsec6_blocklists>	*	*	Security	CrowdSec (IPv6) in	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Block	Active	*	<crowdsec6_blocklists>	*	Security	CrowdSec (IPv6) out	☒
OPNsense	ISO_LAN	Prod_LAN	Cross-Zone	Allow	Active	ISO_LAN	PatchMon_Backend	3000;3001	Patch Management	PatchMon Agent Access	☒
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Admin_Hosts	ISO_LAN	22;80;443;8080;8443;9000;9443	Management	Admin Access to ISO_LAN	☒
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.25/32	ISO_LAN	22	Management	Ansible SSH access	☒
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.126/32	ISO_LAN;Prod_LAN address	1-65535 (TCP/UDP)	Vulnerability Scanning	OpenVAS access for Network/host scanning	☒
OPNsense	Prod_LAN	ISO_LAN	Internal	Allow	Active	This Firewall	*	*	General		☐
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Prod_Network;Lab_Networks;External_LAN	ISO_LAN	*	Diagnostics	Ping tests	☐
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.126/32	This Firewall;Prod_LAN address	9100	Monitoring	Prometheus metrics scrape	☒
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	This Firewall	192.168.1.33	*	General	(Firewall to host)	☐
OPNsense	Prod_LAN	Prod_LAN	Internal	Allow	Active	This Firewall	Asus_Router	*	Routing	OPNsense to Asus Router	☐
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.181/32	ISO_LAN	1-65535 (TCP/UDP)	Monitoring	Uptime Kuma Monitoring for ISO LAN	☐
OPNsense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.181/32	ISO_LAN	*	Monitoring	Uptime Kuma ICMP Monitoring for ISO LAN	☐
pfSense	Prod_LAN	Prod_LAN	Internal	Block	Active	Reserved	*	*	Security	Block bogon networks	☐
pfSense	Prod_LAN	Prod_LAN	Internal	Drop	Active	*	crowdsec6_blacklists	*	Security	Drop crowdsec6_blacklists	☐
pfSense	Prod_LAN	Prod_LAN	Internal	Drop	Active	*	crowdsec_blacklists	*	Security	Pass crowdsec_blacklists	☐
pfSense	Prod_LAN	Prod_LAN	Internal	Allow	Active	*	224.0.0.18	*	HA	VIP Interface Traffic	☐

pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Subnets_ISO	Subnets_Prod_Lab_Ext	*	Diagnostics	Passthrough - ISO LAN Ping testing	☒
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Subnets_ISO	Subnets_Prod_Lab_Ext	33434-33600/UDP	Diagnostics	Passthrough - Allow Linux Host Traceroute	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	Admin_hosts	Subnets_Prod_Lab_Ext	*	Diagnostics	OfficePC/iPad Ping testing to Subnets	☒
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Admin_hosts	Subnets_ISO	*	Diagnostics	OfficePC/iPad Ping testing to Subnets	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	*	*	*	General	Allow all (default allow internal)	☒
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Admin_hosts	Subnets_ISO	22;80;443;8080;8443;9000;9443	Management	OfficePC/iPad access to ISO Subnets	☒
pfSense	Prod_LAN	Lab_LAN2	Cross-Zone	Allow	Active	192.168.1.89	Lab_Network2	80;443;5001;9000;9001;3000-3999;9002	SOC	Cortex to SOC application access	☒
pfSense	Prod_LAN	Lab_LAN2	Cross-Zone	Allow	Active	Prod_Network	192.168.200.41	80;443;5001;3000-9000	SOC	Shuffle Access for Prod_LAN	☒
pfSense	Prod_LAN	Prod_LAN	Internal	Allow	Active	192.168.1.126	Subnets_Prod_Lab_Ext	5000;5050;6556;8000	Monitoring	Checkmk Agent Access	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	Admin_hosts	Subnets_Prod_Lab_Ext	22;80;443;8080;8443;9000;9443	Management	OfficePC/iPad access to all Internal Subnets	☒
pfSense	Prod_LAN	Prod_LAN	Internal	Allow	Active	Traefik_Server	Traefik_Services	7990;8096;32400;9866	Web/Proxy	Traefik Access to Backend Services	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	Prod_Network	Subnets_Prod_Lab_Ext	33434-33600/UDP	Diagnostics	Allow Linux Host Traceroute	☒
pfSense	Prod_LAN	Prod_LAN	Internal	Allow	Active	192.168.1.126	Portainer_Agents	9000	Management	Portainer Manager to Agent Access	☒
pfSense	Prod_LAN	Lab_LAN1	Cross-Zone	Allow	Active	Admin_hosts	192.168.100.5	8834	Management	Admin Host Access to Nessus WebUI	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	192.168.1.166	Subnets_Prod_Lab_Ext	1-65535 (TCP/UDP)	Vulnerability Scanning	OpenVAS Scanning of Internal networks	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	192.168.1.166	Subnets_Prod_Lab_Ext	*	Vulnerability Scanning	OpenVAS ICMP to Internal networks	☒
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.166	Subnets_ISO	*	Vulnerability Scanning	OpenVAS ICMP to ISO networks	☒
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.166	Subnets_ISO	1-65535 (TCP/UDP)	Vulnerability Scanning	OpenVAS Scanning of ISO networks	☒
pfSense	Prod_LAN	Lab_LAN1	Cross-Zone	Allow	Active	Prod_Network	192.168.100.51	443	PKI	ACME Clients to StepCA (HTTPS)	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	Prod_Network	PatchMon_Servers	3000;3001	Patch Management	PatchMon Server Access	☒
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	Subnets_ISO	PatchMon_Servers	3000;3001	Patch Management	PatchMon Server Access for ISO	☒
pfSense	Prod_LAN	Lab_LAN2	Cross-Zone	Allow	Active	Prod_Network	192.168.200.33	9000	SOC	TheHive WebUI access	☒
pfSense	Prod_LAN	Lab_LAN1	Cross-Zone	Allow	Active	AD_Domain_Controller_s	192.168.100.30	88;389;53;636;445;139;135;49152-65535	Directory	Domain Controller initiated traffic to remote PC	☒
pfSense	Prod_LAN	Lab_LAN1	Cross-Zone	Allow	Active	AD_Domain_Controller_s	192.168.100.30	53;88;389;137;138	Directory	Domain Controller initiated traffic to remote PC	☒
pfSense	Prod_LAN	Lab_LAN2	Cross-Zone	Allow	Active	10.20.0.0/24	192.168.200.39	3001	Patch Management	ISO_LAN1 passthrough for PatchMon	☒
pfSense	Prod_LAN	Lab_LAN2	Cross-Zone	Allow	Active	Subnets_Prod_Lab_Ext	192.168.200.8	8220;9200;5044	Logging	Elastic Agent Enrollment and Data Ingestion to Fleet Server	☒
pfSense	Prod_LAN	Lab_LAN2	Cross-Zone	Allow	Active	Admin_hosts	192.168.200.8	5601;8220	Monitoring	Admin Access to Kibana/API	☒
pfSense	Prod_LAN	Lab_LAN1	Cross-Zone	Allow	Active	Admin_hosts	192.168.100.3	80;443;8080;9443	Management	Admin access to pfSense FW Admin Portal	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	192.168.1.181	Subnets_Prod_Lab_Ext	1-65535 (TCP/UDP)	Monitoring	Uptime Kuma access to Internal Subnets	☐
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.181	Subnets_ISO	1-65535 (TCP/UDP)	Monitoring	Uptime Kuma access to ISO Subnets	☐
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	192.168.1.181	Subnets_Prod_Lab_Ext	*	Monitoring	Uptime Kuma ICMP access to Internal Subnets	☐
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.181	Subnets_ISO	*	Monitoring	Uptime Kuma ICMP access to ISO Subnets	☐
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	192.168.1.25	Subnets_Prod_Lab_Ext	22;80;443;8080;8443;9000;9443	Management	Ansible access for host Provisioning	☒
pfSense	Prod_LAN	ISO_LAN	Cross-Zone	Allow	Active	192.168.1.25	Subnets_ISO	22;80;443;8080;8443;9000;9443	Management	Ansible access for host Provisioning	☒
pfSense	Prod_LAN	Multiple	Cross-Zone	Allow	Active	192.168.1.126	Subnets_Prod_Lab_Ext	9100	Monitoring	Prometheus Scrape to Internal Subnets	☒
pfSense	Lab_LAN1	Lab_LAN1	Internal	Block	Active	Reserved	*	*	Security	Block bogus networks	☐
pfSense	Lab_LAN1	Lab_LAN1	Internal	Drop	Active	*	pfB_PRI1_v4	*	Security	pfB_PRI1_v4	☐
pfSense	Lab_LAN1	Lab_LAN1	Internal	Drop	Active	*	crowdsec_blacklists	*	Security	Drop crowdsec_blacklists	☐
pfSense	Lab_LAN1	Lab_LAN1	Internal	Drop	Active	*	crowdsec_blacklists	*	Security	Pass crowdsec_blacklists	☐
pfSense	Lab_LAN1	Lab_LAN1	Internal	Allow	Active	*	224.0.0.18	*	HA	CARP	☒
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	Subnets_Prod_Lab_Ext	192.168.1.126	5000;5050;6556;8000	Monitoring	Checkmk Agent Access	☒
pfSense	Lab_LAN1	Multiple	Cross-Zone	Allow	Active	Lab_Network	Subnets_Prod_Lab_Ext	33434-33600/UDP	Diagnostics	Allow Linux Host Traceroute	☒

pfSense	Lab_LAN1	Lab_LAN1	Internal	Allow	Active	*	This Firewall (self)	80;443;8080;9443	PKI	ACME cert requests	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network	192.168.1.25	*	Management	ansible provisioning	
pfSense	Lab_LAN1	Lab_LAN2	Cross-Zone	Allow	Active	Lab_Network	192.168.200.8	*	Monitoring	Elastic Agents to Indexer	
pfSense	Lab_LAN1	Multiple	Cross-Zone	Allow	Active	192.168.100.5	Subnets_Prod_Lab_Ext	1-65535 (TCP/UDP)	Vulnerability Scanning	Nessus scanner to Internal Subnets	
pfSense	Lab_LAN1	Multiple	Cross-Zone	Allow	Active	192.168.100.5	Subnets_Prod_Lab_Ext	*	Vulnerability Scanning	Nessus scanner ICMP to Internal Subnets	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network	192.168.1.219	1514/UDP;1515/TCP;5500/TCP	EDR	Wazuh EDR Agent to Manager Access	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	192.168.100.51	Subnets_Prod_Lab_Ext	*	PKI	Allow StepCA access to Internal Subnets	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	192.168.100.30	AD_Domain_Controller_s	88;389;53;636;445;139;135;49152-65535	Directory	AD Access - TCP ports for MS Domain Services	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	192.168.100.30	AD_Domain_Controller_s	53;88;389;137;138	Directory	AD Access - UDP ports for MS Domain Services	
pfSense	Lab_LAN1	Multiple	Cross-Zone	Allow	Active	Lab_Network	PatchMon_Servers	3000;3001	Patch Management	PatchMon Server Access	
pfSense	Lab_LAN1	Lab_LAN2	Cross-Zone	Allow	Active	Subnets_Prod_Lab_Ext	192.168.200.8	8220;9200;5044	Monitoring	Elastic Agent Enrollment and Data Ingestion to Fleet Server	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network	Web_server	80;443;8080;9443	Web	internal dashboard access	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network	Reverse_proxy	80;443;8080;9443	Web/Proxy	internal proxy service access	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network	DNS_servers	53/UDP	DNS	DNS access for lab network	
pfSense	Lab_LAN1	Lab_LAN2	Cross-Zone	Allow	Active	Subnets_Prod_Lab_Ext	192.168.200.41	80;443;5001;3000-9000	SOC	Shuffle Access for Internal Subnets	
pfSense	Lab_LAN1	Prod_LAN	Cross-Zone	Allow	Active	192.168.100.15	192.168.1.31	2049;20048;111;4045;875	Storage	NFS Share between OfficePC and Ovrsr	
pfSense	Lab_LAN1	PIA_CAN_MONT	Outbound	Allow	Active	Lab_Network	*	*	VPN	Route out PIA CA Mont	
pfSense	Lab_LAN1	PIA_NY	Outbound	Allow	Active	Lab_Network	*	*	VPN	Route out PIA NY	
pfSense	Lab_LAN2	Lab_LAN2	Internal	Block	Active	Reserved	*	*	Security	Block bogus networks	
pfSense	Lab_LAN2	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	DNS_servers	53/UDP	DNS	DNS access for lab network	
pfSense	Lab_LAN2	Multiple	Cross-Zone	Allow	Active	Lab_Network2	Subnets_Prod_Lab_Ext	33434-33600/UDP	Diagnostics	Allow Linux Host Traceroute	
pfSense	Lab_LAN2	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	192.168.1.219	1514/UDP;1515/TCP;5500/TCP	EDR	Wazuh EDR Agent to Manager Access	
pfSense	Lab_LAN2	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	192.168.100.51	443	PKI	ACME Clients to StepCA (HTTPS)	
pfSense	Lab_LAN2	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	192.168.1.89	80;443;5001;9000;9001;3000-3999;9002	SOC	SOC application to Cortex access	
pfSense	Lab_LAN2	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	192.168.1.181	80;443;8080;9443	Monitoring	Uptime Kuma Application Monitoring	
pfSense	Lab_LAN2	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	Web_server	80;443;8080;9443	Web	internal dashboard access	
pfSense	Lab_LAN2	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	Reverse_proxy	80;443;8080;9443	Web/Proxy	internal proxy service access	
pfSense	Lab_LAN2	Multiple	Cross-Zone	Allow	Active	192.168.200.8	Subnets_Prod_Lab_Ext	8220;9200;5044	Logging	Elastic Fleet Agent Initiated Traffic	
pfSense	Lab_LAN2	Lab_LAN2	Internal	Drop	Active	*	crowdsec_blacklists	*	Security	Drop crowdsec_blacklists	
pfSense	Lab_LAN2	Lab_LAN2	Internal	Drop	Active	*	crowdsec6_blacklists	*	Security	Drop crowdsec6_blacklists	
pfSense	Ext_LAN-DMZ	Ext_LAN-DMZ	Internal	Block	Active	Reserved	*	*	Security	Block bogus networks	
pfSense	Ext_LAN-DMZ	Prod_LAN	Cross-Zone	Allow	Active	Ext_LAN	DNS_servers	53/UDP	DNS	Ext_LAN access to DNS Servers	
pfSense	Ext_LAN-DMZ	Prod_LAN	Cross-Zone	Allow	Active	Ext_LAN	Web_server	80;443;8080;9443	Web	Ext_LAN access to Internal Webserver	
pfSense	Ext_LAN-DMZ	Multiple	Cross-Zone	Allow	Active	Ext_LAN	Subnets_Prod_Lab_Ext	33434-33600/UDP	Diagnostics	Allow Linux Host Traceroute	
pfSense	Ext_LAN-DMZ	Prod_LAN	Cross-Zone	Allow	Active	Ext_LAN	192.168.1.219	1514/UDP;1515/TCP;5500/TCP	EDR	Wazuh EDR Agent to Manager Access	
pfSense	Ext_LAN-DMZ	Lab_LAN1	Cross-Zone	Allow	Active	Ext_LAN	192.168.100.51	443	PKI	ACME Clients to StepCA (HTTPS)	
pfSense	Ext_LAN-DMZ	Multiple	Cross-Zone	Allow	Active	Ext_LAN	PatchMon_Servers	3000;3001	Patch Management	PatchMon Server Access	
pfSense	Ext_LAN-DMZ	Lab_LAN2	Cross-Zone	Allow	Active	Subnets_Prod_Lab_Ext	192.168.200.8	8220;9200;5044	Logging	Elastic Agent Enrollment and Data Ingestion to Fleet Server	
pfSense	Ext_LAN-DMZ	Ext_LAN-DMZ	Internal	Drop	Active	*	crowdsec_blacklists	*	Security	Drop crowdsec_blacklists	
pfSense	Ext_LAN-DMZ	Ext_LAN-DMZ	Internal	Drop	Active	*	crowdsec6_blacklists	*	Security	Drop crowdsec6_blacklists	
pfSense	Prod_LAN	PIA_NY	Cross-Zone	Allow	Disabled	Prod_LAN	Subnets_Prod_Lab_Ext	*	VPN	Route out PIA_NY	
pfSense	Prod_LAN	PIA_CAN_MONT	Outbound	Allow	Disabled	Prod_LAN	Subnets_Prod_Lab_Ext	*	VPN	Route out PIA_CAN_MONT	
pfSense	Lab_LAN1	Verizon	Outbound	Allow	Disabled	Lab_Network	*	*	Internet	Route out Verizon	
pfSense	Lab_LAN2	PIA_CAN_MONT	Outbound	Allow	Disabled	Lab_Network2	*	*	VPN	Route out PIA CA Mont	
pfSense	Lab_LAN2	PIA_NY	Outbound	Allow	Disabled	Lab_Network2	*	*	VPN	Route out PIA NY	
pfSense	Lab_LAN2	Verizon	Outbound	Allow	Disabled	Lab_Network2	*	*	Internet	Route out Verizon	
pfSense	Ext_LAN-DMZ	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network	192.168.1.109	Splunk_Forwarder_Ports	Logging	Splunk Forwarder Access to Indexer	
pfSense	Ext_LAN-DMZ	Prod_LAN	Cross-Zone	Allow	Active	Lab_Network2	192.168.1.109	Splunk_Forwarder_Ports	Logging	Splunk Forwarder Access to Indexer	

Palo Alto-VM	ISO_LAN1	Site2-tunnel	Cross-Zone	Allow	Active	10.20.0.0/24	10.40.0.0/24	*	IPSec VPN	IPSec tunnel - ISO LAN1 to Site2	☐
Palo Alto-VM	Site2-tunnel	ISO_LAN1	Cross-Zone	Allow	Active	10.40.0.0/24	10.20.0.0/24	*	IPSec VPN	IPSec tunnel - Site2 to ISO LAN1	☐
Palo Alto-VM	Site2-tunnel	any	Cross-Zone	Allow	Active	192.168.255.138	192.168.255.139	*	Loopback	Loopback allow outbound - OSPF router-id traffic	☐
Palo Alto-VM	any	Site2-tunnel	Cross-Zone	Allow	Active	192.168.255.139	192.168.255.138	*	Loopback	Loopback allow inbound - OSPF router-id traffic	☐
Palo Alto-VM	Prod_LAN	DMZ	Cross-Zone	Allow	Active	any	192.168.1.138	*	NAT/Proxy	NAT - Prod_LAN to BentoPDF via PA interface IP	☐
Palo Alto-VM	DMZ	Prod_LAN	Cross-Zone	Allow	Active	any	any	app-default	Internet Access	DMZ access to outside (Prod_LAN/internet)	☐
Palo Alto-VM	ISO_LAN1	DMZ; Prod_LAN	Cross-Zone	Block	Active	any	any	app-default	Internet Restrict	Restricted internet access - block netflix/youtube for restricted users	☐
Palo Alto-VM	ISO_LAN1	DMZ; Prod_LAN	Cross-Zone	Allow	Active	any	any	app-default	Internet Access	VIP internet access - allow media/web apps for VIP users	☐
Palo Alto-VM	any	any	Intra-Zone	Allow	Active	any	any	app-default	Microsoft 365	MS Teams / Office365 access - domain users	☐
Palo Alto-VM	Prod_LAN	DMZ	Cross-Zone	Allow	Active	CA; EU; US (geo)	any	*		DMZ access restricted to US/CA/EU source IPs	☐
Palo Alto-VM	Prod_LAN	Prod_LAN	Intra-Zone	Allow	Active	any	192.168.1.138	80;443	GlobalProtect	GlobalProtect portal access - HTTP/HTTPS to PA interface	☐
Palo Alto-VM	Prod_LAN	DMZ; ISO_LAN1	Cross-Zone	Allow	Active	any	10.0.0.0-10.255.255.255; 192.168.0.0-192.168.255.255	*	Management	Firewall admin access to DMZ and ISO_LAN1	☐
Palo Alto-VM	Prod_LAN	DMZ	Cross-Zone	Allow	Active	Internal Networks	any	*	Management	DMZ server admin access for server/DNS/monitoring admins	☐
Palo Alto-VM	any	DMZ	Cross-Zone	Block	Active	any	BentoPDF (192.168.2.12)	*	Security	Deny direct access to BentoPDF - must go through NAT rule	☐
Palo Alto-VM	Prod_LAN	DMZ; ISO_LAN1	Cross-Zone	Allow	Active	Admin Hosts	10.0.0.0-10.255.255.255; 192.168.0.0-192.168.255.255	*	Management	Admin host access to all zones	☐
Palo Alto-VM	DMZ; ISO_LAN1	Prod_LAN	Cross-Zone	Allow	Active	any	DNS Servers	53/UDP	DNS	DNS access from DMZ and ISO_LAN1 to internal DNS servers	☐
Palo Alto-VM	ISO_LAN1	Prod_LAN	Cross-Zone	Allow	Active	any	Elastic Server (192.168.200.8)	8220;9200;5044/TCP	Logging	Elastic Agent enrollment and data ingestion from ISO_LAN1	☐
Palo Alto-VM	Prod_LAN	DMZ; ISO_LAN1	Cross-Zone	Allow	Active	Prometheus Server (192.168.1.126)	any	9100/TCP	Monitoring	Prometheus scrape access to DMZ and ISO_LAN1	☐
Palo Alto-VM	DMZ; ISO_LAN1	Prod_LAN	Cross-Zone	Allow	Active	any	Checkmk Server (192.168.1.126)	5000;5050;6556;8000/TCP	Monitoring	Checkmk monitoring access from DMZ and ISO_LAN1	☐
Palo Alto-VM	DMZ; ISO_LAN1	Prod_LAN	Cross-Zone	Allow	Active	any	Patchmon Servers	3000;3001/TCP	Patch Management	Patchmon server access from DMZ and ISO_LAN1	☐
Palo Alto-VM	Prod_LAN	DMZ; ISO_LAN1	Cross-Zone	Allow	Active	Uptime Kuma Server (192.168.1.181)	any	app-default	Monitoring	Uptime Kuma monitoring probes to DMZ and ISO_LAN1	☐
Palo Alto-VM	DMZ; ISO_LAN1	Prod_LAN	Cross-Zone	Allow	Active	any	Wazuh Server (192.168.1.219)	1514;1414;55000/TCP	Logging	Wazuh agent data ingestion from DMZ and ISO_LAN1	☐
Palo Alto-VM	Prod_LAN	DMZ; ISO_LAN1	Cross-Zone	Allow	Active	Ansible Server (192.168.1.25)	any	22;5985;5986/TCP	Automation	Ansible automation access to DMZ and ISO_LAN1	☐
Palo Alto-VM	DMZ; ISO_LAN1	Prod_LAN	Cross-Zone	Allow	Active	any	Traefik Proxy (192.168.1.247)	80;443/TCP	Proxy	Traefik reverse proxy access from DMZ and ISO_LAN1	☐
Palo Alto-VM	Prod_LAN	DMZ; ISO_LAN1	Cross-Zone	Allow	Active	Nessus Server (192.168.100.5)	any	app-default	Vulnerability Scanning	Nessus vulnerability scanning to DMZ and ISO_LAN1	☐
Palo Alto-VM	Prod-vWire-ingress	Prod-vWire-egress	Cross-Zone	Allow	Active	any	any	*	Virtual Wire	Prod vWire inline - ingress to egress (outbound)	☐
Palo Alto-VM	Prod-vWire-egress	Prod-vWire-ingress	Cross-Zone	Allow	Active	any	any	*	Virtual Wire	Prod vWire inline - egress to ingress (inbound)	☐
Palo Alto-VM	OSPF	ISO_LAN1	Cross-Zone	Allow	Active	any	any	app-default	Management	OSPF zone access to ISO_LAN1 - diagnostics/management	☐
Palo Alto-VM	Prod_LAN	DMZ	Cross-Zone	Block	Disabled	any	BentoPDF (192.168.2.12)	*	Security	Test-BentoPDF - disabled rule (Prod_LAN to BentoPDF direct)	☐
Palo Alto-VM	Site1-tunnel	site2-local	Cross-Zone	Allow	Active	10.20.0.0/24	10.40.0.0/24	*	IPSec VPN	IPSec tunnel - ISO LAN1 (Site1) to Site2 local	☐
Palo Alto-VM	site2-local	Site1-tunnel	Cross-Zone	Allow	Active	10.40.0.0/24	10.20.0.0/24	*	IPSec VPN	IPSec tunnel - Site2 local to ISO LAN1 (Site1)	☐
Palo Alto-VM	Site1-tunnel	any	Cross-Zone	Allow	Active	192.168.255.139	192.168.255.138	*	Loopback	Loopback allow outbound - OSPF router-id traffic	☐
Palo Alto-VM	any	Site1-tunnel	Cross-Zone	Allow	Active	192.168.255.138	192.168.255.139	*	Loopback	Loopback allow inbound - OSPF router-id traffic	☐
Palo Alto-VM	site2-local	site2-local	Intra-Zone	Allow	Disabled	any	any	*	Management	PA-PTP intra-zone site2-local - disabled	☐

Custom IPS/IDS Ruleset – Additional Detail

SSH / Linux Security Controls

SSH Brute-Force Detection

Rule

**alert tcp any any -> 192.168.100.0/24 22 **

(msg:"LAB1: SSH Brute Force Attempt"; flags:S; detection_filter:track by_src, count 5, seconds 60;

sid:910001; rev:2;)

Field Breakdown

Field	Meaning	Impact
alert	Generate an alert when matched	Visible in Suricata → Elastic/Wazuh
tcp	Match only TCP traffic	SSH is TCP-based
any any	Any source IP, any source port	Detects brute force from anywhere
->	Direction operator	Only inbound SSH attempts
192.168.100.0/24 22	Destination network + port	LAB1 SSH servers
flags:S	Match SYN packets only	Prevents noisy alerts from full SSH sessions
detection_filter: track by_src, count 5, seconds 60	Threshold: 5 SYNs in 60 seconds from same IP	Classic brute-force pattern
sid:910001	Unique rule ID	Required for management
rev:2	Revision number	Tracks rule updates

Operational Impact

- Detects brute-force attempts before authentication begins
- Low noise due to SYN-only matching
- Helps identify compromised hosts or bots scanning SSH
- Works across VLAN boundaries

Cross-Segment SSH Policy Enforcement

Rule

**alert tcp 192.168.2.0/24 any -> 192.168.100.0/24 22 **

(msg:"LAB1: SSH Attempt from EXT_LAN"; sid:910002; rev:1;)

Field Breakdown

Field	Meaning	Impact
192.168.2.0/24	EXT_LAN source	DMZ/External-facing internal network
-> 192.168.100.0/24 22	SSH into LAB1	Not allowed by segmentation policy
msg	Alert message	Clear policy violation
sid	Rule ID	Tracking
rev	Revision	Versioning

Operational Impact

- Detects lateral movement attempts from DMZ → LAB
- Enforces segmentation boundaries
- Helps identify compromised DMZ hosts attempting privilege escalation

Privilege Escalation Keyword Monitoring

Rule

```
alert tcp any any -> 192.168.100.0/24 22 \
(msg:"LAB1: sudo Keyword in SSH Session"; content:"sudo"; sid:910003; rev:1;)
```

Field Breakdown

Field	Meaning	Impact
content:"sudo"	Look for the string "sudo" in SSH payload	Detects privilege escalation attempts
tcp	SSH is TCP	Required
any any	Any source	Global monitoring
-> 192.168.100.0/24 22	SSH into LAB1	Target zone

Operational Impact

- Detects sudo usage inside SSH sessions
- Useful for insider threat monitoring
- Helps identify suspicious privilege escalation attempts
- Works best when SSH is not encrypted (lab/testing only)

Reconnaissance & Scanning Detection

Nmap OS Detection Signature

Rule

```
alert tcp any any -> 192.168.100.0/24 any \
(msg:"LAB1: Nmap OS Detection Scan"; content:"| 4E 4D 41 50 |"; sid:910004; rev:1;)
```

Field Breakdown

Field	Meaning	Impact
content:" 4E 4D 41 50 "	Hex for "NMAP"	Matches Nmap OS detection probes
any any	Any source	Detects internal or external recon
-> 192.168.100.0/24 any	Any port	OS detection uses multiple ports

Operational Impact

- Detects active reconnaissance
- Identifies compromised hosts performing mapping
- Useful for early-stage intrusion detection

Behavioral Port Sweep Detection

Rule

```
alert tcp 192.168.100.0/24 any -> 192.168.1.0/24 any \
(msg:"LAB1: LAB → PROD Port Scan"; flags:S; threshold:type both, track by_src, count 20, seconds 10; sid:900008; rev:1;)
```

Field Breakdown

Field	Meaning	Impact
flags:S	SYN packets only	Detects scan attempts, not full sessions
threshold:type both	Count both directions	More accurate scan detection
track by_src	Track per source IP	Identifies scanning host
count 20 seconds 10	20 SYNs in 10 seconds	Classic port sweep behavior
192.168.100.0/24 -> 192.168.1.0/24	LAB → PROD	Enforces segmentation

Operational Impact

- Detects port sweeps from LAB → PROD
- Helps identify malware propagation attempts
- Low false positives due to SYN-only matching

Lateral Movement Prevention

High-Risk Port Access Attempt

Rule

```
alert tcp 192.168.200.0/24 any -> 192.168.1.0/24 [22,135,139,445,3389] \
(msg:"LAB2: LAB → PROD Unauthorized High-Risk Port"; sid:920005; rev:3;)
```

Field Breakdown

Field	Meaning	Impact
192.168.200.0/24	LAB2	Lower-trust zone
-> 192.168.1.0/24	PROD	High-trust zone
[22,135,139,445,3389]	SSH, RPC, NetBIOS, SMB, RDP	Classic lateral movement ports
msg	Clear violation message	SOC visibility
sid	Rule ID	Tracking
rev	Revision	Versioning

Operational Impact

- Detects attempts to pivot into PROD
- Flags malware using SMB/RDP propagation
- Enforces strict trust boundaries

Isolation Network Enforcement

Rule

```
alert ip [10.20.0.0/24,192.168.3.0/24] any -> 192.168.200.0/24 any \
(msg:"LAB2: ISO → LAB2 Traffic (Policy Violation)"; sid:920006; rev:1;)
```

Field Breakdown

Field	Meaning	Impact
alert ip	Match any protocol	Covers TCP, UDP, ICMP, etc.
[10.20.0.0/24,192.168.3.0/24]	ISO networks	Quarantined/isolated zones
-> 192.168.200.0/24	LAB2	Should never communicate
any	Any port	Full isolation enforcement

Operational Impact

- Detects policy violations from isolated networks
- Helps identify misconfigured hosts or malware breakout attempts
- Ensures ISO networks remain fully contained

SMB / NetBIOS Hygiene

NetBIOS Session Service Detection

Rule

```
alert tcp any any -> any 139 \
(msg:"NetBIOS Session Service Detected"; sid:9xxxxx; rev:1;)
```

Field Breakdown

Field	Meaning	Impact
port 139	NetBIOS Session Service	Legacy Windows protocol
any any -> any	Global detection	Hygiene monitoring

Operational Impact

- Detects legacy SMB/NetBIOS traffic
- Useful for identifying outdated systems
- Helps enforce modern SMB hygiene

SMBv1 Protocol Negotiation Detection

Rule

```
alert tcp any any -> any 445 \
(msg:"SMBv1 Protocol Negotiation"; content:"|ff|SMB"; depth:8; sid:9xxxxx; rev:1;)
```

Field Breakdown

Field	Meaning	Impact
port 445	SMB	Modern SMB port
content:" ff SMB"	SMBv1 signature	Detects deprecated protocol
depth:8	Only inspect first 8 bytes	Performance optimization

Operational Impact

- Detects SMBv1 usage (deprecated, insecure)
- Helps enforce compliance and hygiene
- Identifies vulnerable hosts susceptible to EternalBlue-class exploits